

IT RISK MANAGEMENT STANDARDS AND GUIDELINES

Area: IT Audit

(Appendix to Sec. 147-Q/145-S/142-P/126-N (Purpose and Scope and IT Risk Management System))

1. Introduction

- 1.1. BSFIs must plan, manage and monitor rapidly changing technologies to enable them to deliver and support new products, services, and delivery channels. The rate of these changes and the increasing reliance on IT make the inclusion of IT audit coverage essential to an effective overall audit program. The audit program should address IT risk exposures throughout the organization, including the areas of IT management and strategic planning, IT operations, client/server architecture, local and wide-area networks, telecommunications, physical and information security, electronic products and services, systems development and acquisition, and business continuity planning. IT audit should also focus on how management determines the risk exposure from its operations and controls or mitigates identified risks.
- 1.2. A well-planned, properly structured audit program¹ is essential to evaluate risk management practices, internal control systems and compliance with policies concerning IT-related risks at BSFIs of every size and complexity. Effective audit programs are risk-focused, promote sound IT controls, ensure the timely resolution of audit deficiencies and inform the board of directors of the effectiveness of risk management practices. An effective IT audit function may also allow regulators to place substantial reliance on and reduce the time spent reviewing areas of the BSFIs during examinations. Ideally, the audit program should consist of a full-time, continuous program of internal audit which may be further supported by a well-planned external audit program.

2. ROLES AND RESPONSIBILITIES

- 2.1 Board of Directors (Board) and Senior Management. The BSFI's Board or its Audit Committee has the overall responsibility for establishing and maintaining an independent, competent and effective IT audit function commensurate with the complexity of its IT risk profile. In order to properly oversee the IT audit function, the Board or its Audit Committee should:
 - a. Assign responsibility for IT audit function to an internal audit department or individual with sufficient audit expertise, knowledge base and skill level;
 - b. Ensure that IT audit maintains its professional and organizational independence²; and
 - c. Approve and review an audit program that would guide IT audit engagements.
 - d. Senior management is responsible for supporting IT audit by providing sufficient resources, establishing programs defining and requiring compliance with IT planning practices, operating policies and internal controls. Likewise, senior management should not, in any manner, diminish or interfere with the candor of the audit findings and recommendations.
- 2.2. **Audit Management and Audit Staff.** The internal audit manager is responsible for implementing the Board-approved audit directives. The manager oversees the audit function and provides leadership and direction in communicating and monitoring audit policies, practices, programs, and processes. He should establish clear lines of authority and reporting responsibility for all levels of audit personnel and activities. The internal audit manager should also ensure that members of the audit staff possess the necessary independence, experience, education, training, and skills to properly conduct assigned activities. This can be undertaken by providing auditors with an effective program of continuing education and development. As the information systems of a BSFI become more sophisticated or as more complex technologies evolve, the auditor may need additional training.

The primary role of the internal IT audit staff, on the other hand, is to assess independently and objectively the controls, reliability, and integrity of the BSFI's IT environment. Internal auditors should evaluate IT plans, strategies, policies, and procedures to ensure adequate management oversight. They should assess the day-to-day IT controls to ensure that transactions are recorded and processed in compliance with acceptable accounting methods and standards and are in compliance with policies set forth by the Board and senior management. Auditors also perform operational audits, including system development audits, to ensure that internal controls are in place, policies and procedures are effective, and employees operate in compliance with approved policies. Auditors should identify weaknesses, provide meaningful recommendations and review management's plans for addressing those weaknesses, monitor their resolution, and report to the Board material weaknesses, as necessary.

¹ Audit program encompasses audit policies, procedures, and strategies that govern the audit function, including IT audit

² Independence means self-governance, freedom from conflict of interest and undue influence. The IT auditor should be free to make his or her own decisions, not influenced by the organization being audited, or by its managers and employees

- 2.3 **Operating Management.** Operating management should formally and effectively respond to IT audit or examination findings and recommendations. The audit procedures should clearly identify the methods for following up on noted audit or control exceptions or weaknesses. Operating management is responsible for correcting the root causes of the audit or control exceptions, not just treating the exceptions themselves. Response times for correcting noted deficiencies should be reasonable and may vary depending on the complexity of the corrective action and the risk of inaction.

3. INDEPENDENCE OF THE IT AUDIT FUNCTION

- 3.1 The ability of the internal audit function to achieve desired objectives depends largely on the independence of audit personnel. Hence, the placement of the internal audit function in relation to the BSFI's management structure should be carefully assessed. The degree of auditors' independence, objectivity and impartiality entails the following key elements:
- a. Direct reporting of audit results to the Board or its Audit Committee;
 - b. Full authority vested by the Board to the IT Audit Department/IT auditor to access all records and staff necessary to conduct the audit and require management to address significant findings in a timely manner. Said authority must be clearly specified in an Internal Audit Charter or Audit Program duly approved by the Board or Audit Committee;
 - c. Non-involvement of IT audit personnel in management/operational activities that may compromise or appear to compromise their independence; and
 - d. The Board or Audit Committee should decide on audit personnel performance evaluation and compensation matters.

4. INTERNAL IT AUDIT PROGRAM

- 4.1 A formal audit program or manual consisting of policies and procedures governing the IT audit function should be adopted commensurate with the BSFI's size, complexity, scope of activities and risk profile. The audit program should, at a minimum, encompass the following components:
- a. A mission statement or audit charter¹ outlining the purpose, objectives, organization, authorities, and responsibilities of the internal auditor, audit staff, audit management, and the audit committee;
 - b. A risk assessment process to describe and analyze the risks inherent in a given line of business and drive the scope and frequency of audits. Auditors should update the risk assessment at least annually, or more frequently if necessary, to reflect changes to internal control or work processes;
 - c. An annual audit plan detailing IT audit's budgeting and planning processes to include audit goals, schedules, staffing needs and reporting;
 - d. An audit cycle that identifies the frequency of audits which should be based on a sound risk assessment process;
 - e. Well-planned and properly structured audit work programs² that set out the required scope and resources, including the selection of audit procedures, extent of testing and the basis for conclusions for each audit area;
 - f. Audit report preparation standards that require the use of an approved audit rating system;
 - g. Requirements for audit work paper documentation to ensure clear support for all audit findings and work performed, including work paper retention policies;
 - h. Follow-up processes that require internal auditors to determine the disposition of management actions to correct significant deficiencies;
 - i. Policies on outsourcing of some or all of IT audit function, including technical/highly specialized reviews, to external third parties; and
 - j. Professional development programs for audit staff/personnel to maintain the necessary technical expertise.

¹ Audit charter is a document approved by the Board of Directors that defines the IT audit function's responsibility, authority and accountability

² Work program is a series of specific, detailed steps to achieve an audit objective.

Additionally, the BSFI should consider conducting its internal audit activities in accordance with professional standards, such as the Standards for the Professional Practice of Internal Auditing issued by the Institute of Internal Auditors (IIA), and those issued by the Standards Board of the Information Systems Audit and Control Association (ISACA), whenever possible.

5. IT AUDIT PHASES

- 5.1 **Audit Planning.** The BSFI should develop an overall audit plan¹ for all the audit assignments/engagements covering at least twelve (12) months to ensure adequate coverage of IT risks. The plan should be defined by combining the results of the risk assessments and the resources required to yield the timing and frequency of planned internal audits. The audit plan must be realistic and should cover a time budget for other assignments and activities such as specific examination, consulting/advisory services, training and provision for audit personnel leave of absences.

The audit plan must be formally approved and regularly reviewed by the Board or Audit Committee. The internal auditors should report the status of the planned versus actual audits and any revisions to the annual audit plan on a periodic basis.

For each audit assignment, an audit work program detailing the objectives, scope, nature and extent of audit procedures and outline of audit work should be prepared. This is to ensure that appropriate attention is devoted to important areas of the audit, potential problems are identified and resolved on a timely basis, and the audit engagement is properly organized and managed to be performed in an effective and efficient manner.

- 5.2. **Risk Assessment.** The use of an appropriate risk assessment technique or approach is critical in developing the overall IT audit plan and in planning specific audits. An effective risk assessment methodology should be defined to provide the Board or its Audit Committee with objective information in determining audit priorities for the effective allocation of IT audit resources. The risk assessment for IT audit planning should:

- a. Identify the BSFI's data, application² and operating systems³, technology, facilities, and personnel;
- b. Identify the business activities and processes within each of those categories;
- c. Include profiles of significant business units, departments, and product lines, or systems, and their associated business risks and control features, resulting in a document describing the structure of risk and controls throughout the BSFI; and
- d. Use a measurement or scoring system that ranks and evaluates business and control risks for significant business units, departments, and products.

The results of the risk assessments, in support of the audit plan, must be presented to the Board or Audit Committee for review and approval. A process must be in place to ensure regular monitoring of the results of the risk assessment and updating it at least annually for all significant business units, departments, and products or systems.

A risk scoring model or system may be adopted to provide a sound basis for the risk assessment. Among the major risk factors that may be used in scoring systems include the following: a) Adequacy of internal controls; b) Nature of transactions and operating environment; c) Age of the system or application; d) Physical and logical security of information, equipment, and premises; e) Adequacy of operating management oversight and monitoring; f) Previous regulatory examination and audit results and management's responsiveness in addressing issues; g) Human resources, including the experience of management and staff, turnover, technical competence, management's succession plan, and the degree of delegation; and h) Senior management oversight.

Written guidelines on the use of risk assessment tools and risk factors should be approved and reviewed by the Board or its Audit Committee. IT auditors should use the guidelines to grade or assess major risk areas and to define the range of scores or assessments (e.g., groupings such as high, medium or low risk or numeric risk ratings). At a minimum, the written assessment guidelines should specify the following elements: a) Maximum length for audit cycles based on the risk scores; b) Timing of risk assessments for each department or activity; c) Documentation requirements to support scoring decisions; and d) Guidelines for overriding risk assessments in special cases and the circumstances under which they can be overridden.

¹ Audit plan is a description and schedule of audits to be performed in a certain period of time (ordinarily a year). It includes the areas to be audited, the type of work planned, the high-level objectives and scope of the work and includes other items such as budget, resource allocation, schedule dates, and type of report issued.

² Application system is an integrated set of computer programs designed to serve a well-defined function and having specific input, processing, and output activities (e.g., CASA, general ledger, loans and treasury systems).

³ Operating system is the program that manages all the basic functions and programs in a computer.

5.3 Performance of Audit Work. Depending on the complexity of IT risk profile, IT auditors may perform all or a combination of any of the following IT audit procedures:

- a. **IT General Controls Review** – This entails the review of the adequacy of general controls¹ in place to ensure proper management and monitoring of IT risks/environment and the effective functioning of the BSFI's IT systems and infrastructure. The following areas should be covered, among others: a) IT management and strategic planning; b) IT operations; c) Client/server architecture; d) Local and wide-area networks; e) Telecommunications; and f) Physical and information security.

IT general controls review may be carried out through the audit of each IT unit or department in the institution (e.g., IT Operations, Network and Communications, etc.).

- b. **Application Systems Review** -The purpose of this review is to identify, document, test and evaluate the application controls² that are implemented to ensure the confidentiality, integrity and accuracy of the system processing and the related data. The application-level risks to the system and data addressed by this review are the following, among others: a) System availability risks relating to the lack of system operational capability; b) System security risks relating to unauthorized access to systems and/or data; c) System integrity risks relating to incomplete, inaccurate, untimely or unauthorized processing of data; d) System maintainability risks relating to inability to update the system when required in a manner that continues to provide for system availability, security and integrity; and e) Data risks relating to its completeness, integrity, confidentiality, privacy and accuracy.
- c. **Technical Reviews** -BSFIs with complex IT risk profile such as those providing electronic products and services and web-enabled facilities, also require IT auditors to perform highly technical/specialized reviews such as the conduct of periodic internal vulnerability assessment and penetration testing, computer forensics and review of emerging technologies, e.g., cloud computing, virtualization, mobile computing.

IT auditors frequently use computer-assisted audit techniques (CAATs) to improve audit coverage by reducing the cost of testing and sampling procedures that otherwise would be performed manually. CAATs include many types of tools and techniques, such as generalized audit software, utility software, test data, application software tracing and mapping, and audit expert systems. These tools and techniques can also be used effectively to check data integrity by testing the logical processing of data “through” the system, rather than by relying only on validations of input and output controls.

Audit software programs should remain under the strict control of the audit department. For this reason, all documentation, test material, source listings, source and object program modules, and all changes to such programs, should be strictly controlled. Computer programs intended for audit use should be carefully documented to define their purpose and to ensure their continued usefulness and reliability.

All audit procedures forming part of the assignment should be documented in working papers. These must reflect the examinations that have been made and emphasize the evaluations formulated in the report. The working papers must be drawn up according to a well-determined method. Such method must provide sufficient information to verify whether the assignment was duly performed and to enable others to check the manner in which it was performed.

5.4 Reporting. A written audit report of each assignment is to be issued to the auditee and Audit Committee within a reasonable timeline. The audit report should state the scope, objectives, period of coverage and the nature, timing and extent of the audit work performed. It should state the findings, conclusions and recommendations and any reservations, qualifications or limitations in scope that the IT auditor has with respect to the audit. The IT audit should discuss the draft report contents with management in the subject area prior to finalization and release of the final report. This should be signed, dated and distributed according to the terms of the audit charter/audit program or engagement letter.

5.5 Post-closing/Monitoring Activities

Senior management should ensure that the internal audit department's concerns are appropriately addressed. Therefore, they should approve a procedure established by the internal audit department to ensure the consideration and, if appropriate, timely implementation of audit recommendations.

¹ General controls are controls, other than application controls, that relate to the environment within which application systems are developed, maintained, and operated, and that are therefore applicable to all the applications at an institution. Like application controls, general controls may be either manual or automated. Examples of general controls include the development and implementation of an IT strategy and an IT security policy, the organization of IT staff to separate conflicting duties and planning for disaster prevention and recovery.

² Application controls are controls related to transactions and data within application systems. Application controls ensure the completeness and accuracy of the records and the validity of the entries made resulting from both programmed processing and manual data entry. Examples of application controls include data input validation, agreement of batch totals and encryption of data transmitted.

The IT audit department should monitor the implementation of management's corrective actions for proper disposition of its findings/recommendation. The status of the recommendations is communicated at least on a quarterly basis to the Board or Audit Committee.

6. OTHER IT AUDIT ACTIVITIES/PARTICIPATION

- 6.1 Development, Acquisition, Conversions and Testing.** The BSFI's Board-approved audit policy should include guidelines detailing what involvement internal audit will have in the development, acquisition, conversion, and testing of major applications. This includes describing the monitoring, reporting, and escalation processes (when internal controls are found to be insufficient or when testing is found to be inadequate). For acquisitions with significant IT impacts, participation of IT audit may be necessary early in the due diligence stage.

It is necessary that audit's participation in the development process be independent and objective. Auditors can determine and should recommend appropriate controls to project management. However, such recommendations do not necessarily "pre-approve" the controls, but instead guide the developers in considering appropriate control standards and structures throughout their project.

- 6.2 Review of Technology Service Providers (TSP).** The BSFI should effectively manage its relationships with key TSPs through review and assessment of adequacy of IT controls employed by such TSPs. When circumstances warrant, the BSFI's internal audit function may be utilized to directly audit TSP's operations and controls. In some instances, the services of external auditors may be employed. A BSFI using external audit to complement its own coverage should ensure that the independent auditor is qualified to perform the review, that the scope satisfies its own audit objectives and that any significant reported deficiencies are corrected.

7. OUTSOURCING OF IT AUDIT FUNCTIONS

- 7.1** The Board and senior management of a BSFI that outsources its internal IT audit function should ensure that the structure, scope and management of the outsourcing arrangement provides for an adequate evaluation of the system of internal controls. Management should ensure that there are no conflicts of interest and that the use of these services does not compromise independence.
- 7.2.** When negotiating the outsourcing arrangement with a service provider, the BSFI should carefully consider its current and anticipated business risks in setting each party's internal audit responsibilities. To clearly define the BSFI's duties and those of the audit provider, it should have a written contract, often referred to as an engagement letter¹.

(Circular Nos. 970 dated 22 August 2017 and 958 dated 25 April 2017)

¹ In general, the contract between the institution and the audit provider may or may not be the same as the engagement letter.

IT RISK MANAGEMENT STANDARDS AND GUIDELINES

Area: Information Security

(Appendix to Sec. 147-Q/145-S/142-P/126-N (Purpose and Scope and IT Risk Management System))

1. INTRODUCTION

- 1.1 Information, as one of the most critical assets of Bangko Sentral Supervised Financial Institutions (BSFIs), should be accorded with adequate level of protection and risk management controls to preserve its confidentiality, integrity, and availability. BSFIs are increasingly relying on information to achieve business goals and objectives, drive core operations, and support critical decisions. With the emergence of new business models in a predominantly information-driven economy, information that is timely, accurate, and reliable becomes even more important. Effectively addressing information security requirements enables BSFIs to remain competitive and relevant as the financial services industry moves towards digital innovation. Thus, BSFIs need to prioritize information security risk management (ISRM) aligned with their business goals and objectives.
- 1.2 Information security instills trust and confidence between BSFIs and their customers, ensures compliance with laws and regulations, and improves enterprise value. Because information security is intrinsically linked to the overall safety and soundness of BSFIs, the Board of Directors (Board) and Senior Management should exercise effective information security governance to ensure ongoing alignment of information security with business needs and requirements. Information security risks and exposures must be managed to within acceptable levels through a dynamic interplay of people, policies and processes, and technologies and must be integrated with the enterprise-wide risk management system.
- 1.3 The frequency, severity, and visibility of recent cyber-attacks highlight, not only the degree of disruption to business operations, but also the extent of reputational damage which could undermine public trust and confidence in the financial system. If not properly managed, cyber-attacks may result to operational, legal, reputational, and systemic risks. In light of the growing concerns on cybersecurity, a key component of information security, BSFIs should put greater emphasis on cybersecurity controls and measures in managing information security risks.

2. INFORMATION SECURITY GOVERNANCE

- 2.1. **Information Security Strategic Plan.** An information security strategic plan (ISSP), aligned with the BSFI's business plan, must be established to clearly articulate the Board and Senior Management's direction on information security. The ISSP should provide a roadmap that would guide the BSFI in transforming the current state of security to the desired state taking into account business goals and strategies. In defining the desired state of security, the concerned BSFI should consider key elements, to include principles and policy framework, organizational structures and culture, information/data, services, IT infrastructure, and people.

The BSFI may utilize commonly accepted approaches or frameworks in developing the ISSP tailored to its specific business and technology profile. The ISSP must be reviewed at least annually by the Board and Senior Management and regularly updated in line with changes in business strategies, IT infrastructure and services, and operating environment.

- 2.2. **Information Security Program.** The BSFI should maintain a comprehensive, well- designed and effective Information Security Program (ISP) commensurate with its operational and IT profile complexity. The ISP is essentially the mechanism to implement the ISSP which must be aligned with business needs and strategies and integrated across all facets of the business environment. To ensure its effectiveness and sustainability, the ISP should have strong support from the Board and Senior Management as well as cooperation of all concerned stakeholders. The program should clearly establish security roles, responsibilities and accountabilities, and provide mechanisms to ensure enforcement and compliance (e.g. formal disciplinary process and corresponding actions for those who have committed security violations). The ISP generally covers security policies, standards and procedures, security operations, technologies, and organizational structures as well as security awareness and training programs aimed at protecting BSFI's information assets and supporting infrastructure from internal and external threats.

The ISP should be reviewed and tested at planned intervals to ensure its continuing suitability, adequacy, and effectiveness. Management should adjust the ISP to reflect the results of ongoing risk assessment, analyses of emerging internal and external threats and vulnerabilities, cyber-intelligence gathered from information sharing groups, and the level of effectiveness of the existing security controls. Further, Management should take into account

changes in the IT infrastructure/systems and business arrangements such as mergers, acquisitions, alliances and joint ventures, and outsourcing agreements.

- 2.3 **Security Culture.** The Board and Senior Management should take the lead in establishing an information security culture that regards security as an intrinsic part of the BSFI's core business and operations. Instilling a strong security culture ensures that security controls, processes and measures are deeply embedded into the BSFI's lines of business, products, services and processes, including its employees and external relationships. Having a strong security culture will help facilitate attainment of the institution's desired state of security and level of maturity as well as more effective and efficient implementation of the ISSP and ISP. The level of compliance of employees to the security policies, employees' knowledge in identifying and reporting incidents, and the degree of integration of security requirements throughout the life cycles of services and applications are some indicators of an institution's security culture. The Board and Senior Management should adopt the right mindset and understand the crucial role of information security in supporting/achieving business goals and objectives. In line with this, the Board and Senior Management should provide the necessary resources to develop, maintain, and implement the ISP.
- 2.4 **Responsibility and Accountability.** Information security roles and responsibilities span the entire organization from the Board and Senior Management, business line managers, security department, down to the employees. The BSFI's Board and Senior Management set the overall tone and strategic direction for information security by providing strong leadership and effective information security governance. The Board, or an appropriate Board committee, is responsible for overseeing the development, implementation and maintenance of the BSFI's ISSP and ISP. The Board should understand the business case for information security as well as the impact of information security risks to the business. Relative thereto, the Board should approve and provide adequate funding and other necessary resources for security projects and initiatives to effectively implement the ISSP and ISP. The Board or a Board-designated committee should approve and review the written ISSP and ISP including the corresponding security policies and standards at least annually. The Board or a Board-designated committee should likewise periodically review the assessments of the overall effectiveness of the program and direct Senior Management to undertake corrective actions, when necessary.

Senior Management is generally responsible and accountable in executing the ISSP and ISP within the bounds and thresholds set by the Board. Senior Management plays a key role in providing leadership and support for information security as well as balancing business and security requirements and managing information security risks within acceptable levels. Senior Management should appoint a Chief Information Security Officer (CISO) who will be responsible and accountable for the organization-wide ISP. The duly appointed CISO is a senior level executive with sufficient authority within the institution to effectively perform the following functions and responsibilities, among others:

- a. Formulate the ISSP and ISP for approval by the Board and Senior Management;
- b. Implement and manage the duly-approved ISSP and ISP;
- c. Coordinate and work with business process owners and executives across different departments to ensure that information security requirements support business needs and security systems and processes are working as intended;
- d. Enforce compliance with the ISP and the corresponding policies, standards and procedures across the organization and conduct security awareness and training programs catered to different sets of stakeholders;
- e. Educate, inform, and report to the Board and Senior Management relevant information security issues and concerns;
- f. Prepare business cases for certain security control technologies, products, and arrangements for Board and Senior Management's approval;
- g. Ensure that security controls and processes are embedded throughout the lifecycle of information, systems, applications, products and services;
- h. Assist in the effective implementation of information security incident response plan; and
- i. Assist in ensuring regulatory compliance and adherence to information security-related laws, rules and regulations.

In addition to the minimum qualifications provided in Sec. 134, the appointed CISO should have sufficient knowledge, technical background, skills and training to enable him to perform the above assigned tasks. To ensure appropriate segregation of duties, the CISO should report directly to the Board, designated Board committee or to Senior Management and have sufficient independence to perform his mandate. The CISO should perform the tasks of a risk manager and should be independent from the IT department. For BSFIs with moderate to complex IT profile classification, the CISO may be the head of an information security office/unit, staffed with a number of highly skilled security specialists. In the case of BSFIs with simple IT profile, the CISO function may be assigned to an existing independent officer who meets the above qualifications.

The BSFI's IT department also plays a crucial role in maintaining security within the technology domain. Considering that security controls and measures are largely automated and technology-driven, it may be more feasible for BSFI's security operations personnel and IT personnel to share some security administration functions. IT personnel are usually charged in managing the security configuration of servers, databases, routers, switches and other security technologies that are deeply embedded in systems/applications.

Security specialists, on the other hand, are responsible in managing the more specialized security tools and technologies such as Security Information and Event Management (SIEM) tools, vulnerability scanners, and other management support technologies.

Insofar as the ISP includes physical security as one of the IS controls, the CISO may need to coordinate with the BSFI's Chief Security Officer or Bank Security Officer on IS matters/incidents that entail physical security considerations. The CISO should also collaborate with fraud management units (FMU), particularly in monitoring emerging security and fraud risks involving customer accounts.

Business line managers, application/system and information owners are generally responsible for information asset classification and determining the required level of security requirements to support business requirements. They are also responsible in defining and granting access rights of employees and ongoing monitoring of the appropriateness of such access rights. On the other hand, employees, as the first line of defense, should understand and abide by the security policies, standards and procedures. They are responsible in monitoring and reporting security-related incidents and security lapses within their job functions in accordance with the information security incident response plans. To ensure their ongoing commitment and awareness, employees should regularly attend security awareness trainings and other programs.

- 2.5. **Resources.** The Board and Senior Management should see to it that adequate resources, organizational functions/capabilities, policies, standards and procedures as well as the supporting infrastructure commensurate with the BSFI's IT profile classification and risk appetite, are available and optimized to effectively implement the institution's ISSP and ISP. Without sufficient resources in terms of funding/budget allocations, skilled manpower and underlying technologies, implementation of the ISP may suffer leading to security lapses, incidents and poorly designed/implemented security systems. Thus, it is crucial that sufficient resources are devoted to information security operations and initiatives. Further, Management may supplement its existing security skills and capabilities through outsourcing of certain security functions to third party service providers, including cloud service providers. In such cases, the institution needs to provide adequate oversight and institute robust risk management processes and practices pursuant to existing regulations on outsourcing and cloud computing.
- 2.6. **Compliance with Relevant Laws, Regulations and Standards.** In designing the ISSP and ISP, compliance with relevant laws, regulations, and standards must be fully considered. For BSFIs, these include The Law on Secrecy of Bank Deposits under R.A. No. 1405 and recently, the Data Privacy Act of 2012 under R.A. No. 10173. For BSFIs that process and issue payment cards under international brand schemes (e.g., VISA, Mastercard, AMEX, etc.), the ISP should be tailored to fit the requirements of the Payment Card Industry Data Security Standard (PCI DSS). Moreover, Management may find having security certifications such as those provided by the International Organization for Standardization (ISO) and other certifying bodies to be of significant value to the business.

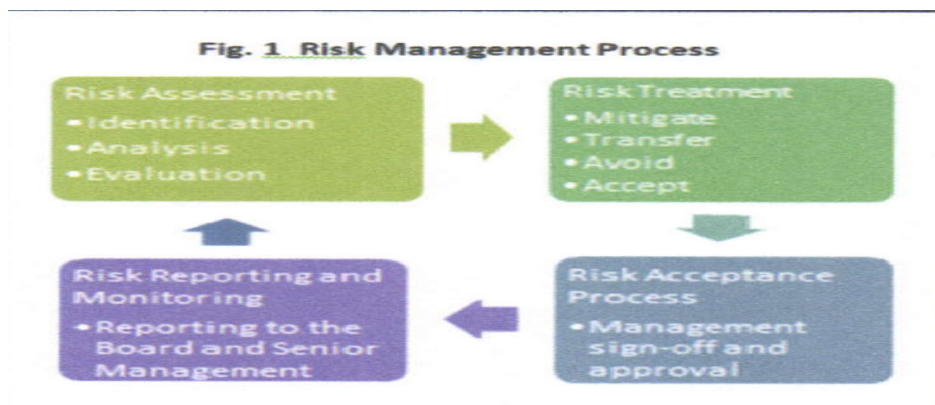
These certifications serve as proof of certain quality and standards in terms of information security management systems which may enhance customers' and stakeholders' confidence, facilitate regulatory compliance on security, and enable achievement of desired security posture and maturity. While not specifically required under the Bangko Sentral regulations, obtaining security certifications may be considered a sound security practice that may speed up the maturity level of the BSFI and a sound indicator of effective information security culture. Management should continually assess the regulatory environment and adjust/update their ISSP and ISP accordingly to ensure continuing compliance.

3. ISP MANAGEMENT

- 3.1. **Information Security Risk Management System.** The Information Security Risk Management (ISRM) system should be an integral part of the organization's ISP and enterprise-wide risk management system. The ISRM framework, including cybersecurity elements, should be commensurate to the level of risk profile of the BSFI. The design and implementation of the ISRM system largely depends on the BSFI's culture, mission and objectives, organizational structure, products, services, and management/operational processes. To ensure that appropriate information

security controls and maturity levels are achieved, Management may refer to leading standards and technology frameworks¹ in designing the institution's own ISRM framework.

3.1.1. Risk Management Process.



Management should conduct periodic security risk assessment to identify and understand risk on confidentiality, integrity and availability of information and IT systems based on current and detailed knowledge on BSFI's operating and business environment. This includes identifying information security risks relative to its internal networks, hardware, software, applications, systems interfaces, operations and human elements. The risk assessment should include an identification of information and IT resources to be protected and their potential threats and vulnerabilities. This risk identification phase should be comprehensive to cover all possible risk scenarios that may hamper the confidentiality, integrity and availability of information assets.

An effective risk assessment process involves three phases namely: risk identification, analysis and evaluation. Vendor concerns place additional elements to the process. The risk identification process, including the elements that the BSFI needs to consider is further detailed in item 3.2 Identification phase.

Once the risks are identified, Management should undertake a systematic risk analysis phase whereby the likelihood and impact of threats and vulnerabilities are assessed. It should utilize clearly defined and consistent risk measurement approaches in analyzing and evaluating risks. After which, the appropriate risk treatment options (i.e., mitigate, transfer, avoid or accept) should be applied taking into consideration the BSFI's risk appetite and tolerance. Once the BSFI identifies the risks to mitigate, Management can begin to develop risk mitigation strategy which should be an integral component of the ISP. The risk management phases from identification to risk treatment should flow into the BSFI's risk reporting and monitoring activities to ensure effectiveness and continuous improvement of the entire risk management process. The results of the risk management processes should be communicated to the concerned stakeholders and reported to the Board and Senior Management for appropriate risk decisions.

3.1.1.1. **Insurance.** The BSFI may avail of insurance coverage for information security- related events and incidents as a way to transfer risks. It is, however, not to be construed as a substitute for an effective ISP. Insurance is a logical risk treatment option for risk exposures with high impact but with low probabilities (e.g., fire, earthquakes, massive cyber-attacks, etc.). Hence, it should carefully evaluate the extent and availability of coverage in relation to the magnitude and probability of the risks. Likewise, Management should ensure compliance with relevant security controls and policies as stipulated in the insurance policy.

3.2. **Identification.** Management should be able to identify the BSFI's information security as well as cyber-related risks through a thorough understanding of its business processes and functions, information assets and related access, threats and vulnerabilities, interconnections, and security architecture. The identification process is the first crucial step to information security risk management and should be robust enough to ensure that all foreseeable risks and

¹ US National Institute of Standards and Technology (NIST), ISO, US FFIEC, COBIT and CPMI publications, among others.

threats are identified. Failure to identify key information security risks would significantly hamper the security posture, as such would no longer be considered in the analysis and mitigation phases.

3.2.1. Business Processes and Functions. The BSFI constantly faces the challenge of balancing its security requirements versus performance objectives and costs. Similar to the conduct of business impact analysis (BIA), Management should identify all business processes and functions, including their dependencies and consequently assess and determine their criticality and importance to the business. This exercise should guide the BSFI's decision-makers in prioritizing preventive, detective, response and recovery efforts. The level and degree of security controls and measures are expected to be commensurate to the criticality and importance of the business processes and functions. At a minimum, Management should ensure that the ISP is able to adequately support/secure the institution's critical business processes and functions.

3.2.2. Information Assets and Related Access. The BSFI should maintain an inventory of all information systems assets that include components from all information systems. In developing an information systems assets inventory, it should be able to document system-specific information (e.g., hardware inventory specifications, software license information, software version numbers, component owners, machine names, network address, manufacturer, device type, model, serial number, and physical location) that will allow Management to:

- a. Identify the information owner who shall be responsible in ensuring confidentiality, integrity, and protection of these assets;
- b. Associate the interdependencies of these systems and understand how these systems support the associated business lines;
- c. Facilitate an efficient process for system installations, removals, and other updates; and
- d. Monitor system configuration activities and detect unauthorized changes to the systems in a timely manner.

3.2.3. Threats and Vulnerabilities. In identifying risks, the BSFI should have a documented process that will determine the threats and vulnerabilities to the institution's IT environment. A threat is anything or anyone that has the potential to adversely impact the institution by exploiting vulnerability in people, process, and/or technology. Given the broad definition of threat, the BSFI should establish a structured approach that will allow Management to have a holistic view of the threat landscape. This can be done by maintaining robust threat intelligence feeds from various sources such as publicly available data from news media, publications and websites as well as subscription to information security vendors and information-sharing organizations.

Threat identification and management programs should enable the BSFI to:

- a. Identify and understand the nature, frequency, and sophistication of threats;
- b. Categorize threats, sources, and vulnerabilities;
- c. Aggregate and quantify potential threats;
- d. Evaluate the corresponding information security risks to the institution; and
- e. Develop appropriate risk mitigation strategies as part of the ISP.

As threats continue to evolve rapidly and increase in sophistication, Management should ensure that threat monitoring and vulnerability scanning tools and processes remain effective in identifying both known and unknown (zero-day¹) security exposures.

3.2.4. Interconnections. The BSFI's business processes often deal with exchanging information and conducting transactions in an online and interconnected environment which inevitably require third-party connections to its network and computing resources and vice versa. These arrangements should be governed by terms and conditions that clearly establish the duties and responsibilities of both parties in owning, operating, and/or maintaining the information systems. The extent of interconnection may result to risks that may weaken the institution's security posture.

As such, it should identify connections with external parties, including other BSFIs, financial market infrastructures and third party service providers, their corresponding access points and channels and systems/applications accessed. Consequently, Management should assess the BSFI's interconnectivity risks and implement appropriate risk mitigation controls to improve resilience of the entire ecosystem.

¹ Refers to the exploit of zero-day vulnerability which takes place on the same day the vulnerability becomes generally known. It also means zero days between the time the vulnerability is discovered and the first attack.

3.2.5. **Security Architecture.** Given the increasing interconnectivity and complexity of information systems and security infrastructure, developing an information security architecture using generally acceptable architectural approaches can provide the BSFI with a holistic view of existing security controls and processes, the taxonomy of business processes and information and information flows and their interdependencies. For complex BSFIs, an information security architecture that is aligned with their enterprise architecture should be adequately documented. The development of the information security architecture should also incorporate security controls needed to support data privacy requirements. The information security architecture generally includes an architectural description, placement of security controls, security-related information for external interfaces, information being exchanged across the interfaces, and protection mechanisms associated with each interface.

3.3. **Prevention.** Management should put in place adequate protection mechanisms and controls to prevent security incidents and risks from materializing. These include measures ranging from baseline to advanced tools and approaches such as defense-in-depth, malware prevention, access controls, and cybersecurity awareness programs, among others. These preventive controls are generally categorized into three types, namely: administrative, physical and environmental, and technical controls.

3.3.1. **Administrative Controls.** The BSFI should establish administrative controls to clearly articulate the Board and Senior Management's intent, expectations, and direction on information security. Administrative controls generally address the human factor affecting information security within all levels of the organization.

3.3.1.1. **Policies, Standards, and Procedures.** Management should formulate written information security policies, standards, and procedures which define the institution's control environment and guide employees on the required, expected, and prohibited activities. Policies, standards, and procedures serve as a primary tool in the exercise of effective information security governance, hence, they should be able to capture the Board and Senior Management's security direction and risk appetite. The Board and Senior Management should approve and periodically review policies, standards, and procedures to ensure ongoing alignment with business needs and requirements. Policies, standards, and procedures should have the following attributes:

- a. Documented using clear, simple, and unambiguous language and widely communicated to all employees and concerned stakeholders;
- b. Comprehensive and complete covering all aspects of ISRM such as, but not limited to, security organizational structure, physical, environmental and logical security, communications and operations management, and human resources security;
- c. Tailored to the needs and requirements, including the security culture of the institution; and
- d. Adaptable to the changing business, regulatory, and operating environment.

3.3.1.1.1. **Minimum Baseline Security Standards.** Management should put in place minimum baseline security standards (MBSS) to ensure that systems, hardware, and network devices are consistently and securely configured across the organization. These standards enable the deployment of operating systems, databases, network devices, and mobile devices within the IT environment in an efficient and standardized manner. Management may refer to leading standards and best practices as well as vendor-specific recommendations in developing their MBSS, taking into consideration the following controls:

- a. Secure configuration of operating systems, system software, databases, and servers to meet the intended uses with all unnecessary services and programs disabled or removed;
- b. Periodic checking to ensure that baseline standards are consistently complied with;
- c. Timely deployment of tested and approved patches and security updates;

- d. Adequate documentation of all configurations and settings of operating systems, system software, databases, and servers; and
- e. Adequate logging capabilities for all systems, applications, network devices, and databases.

3.3.1.2. **Security Training and Awareness Programs.** All employees of the organization and, where relevant, contractors and third party users should receive appropriate information security awareness training and regular updates in organizational policies and procedures relevant to their job function. Awareness and education are vital components in the overall security strategy of the BSFI as they address the weakest link in the security chain. Security training and awareness programs promote a security conscious environment and strengthen compliance with the BSFI's security policies, standards, and procedures.

Security training and awareness programs should be designed and tailored to the specific requirements of different groups and stakeholders (i.e., business process/information owners, security specialists, incident responders, etc.). The program should be constantly updated to cover emerging threats and risks and must include defined metrics to enable the BSFI to assess its effectiveness over time.

3.3.1.3. **Security Screening in Hiring Practices.** Management should have a process to verify job application information of all new employees. Screening procedures, including verification and background checks, should be developed for recruitment of permanent and temporary IT staff, and contractors, particularly for sensitive IT-related jobs or access level. Similar checks should be conducted for all staff, including contractors, at regular intervals throughout their employment, commensurate with the nature and sensitivity of their job functions as well as their access to critical systems. Management should be aware of changing personal circumstances of employees and contractors that may be indicative of potential increased incentives for system misuse or fraud. Further, it should establish processes and controls to mitigate risks related to employees' termination/resignation or changing responsibilities.

3.3.1.4. **Security Screening in Hiring Practices.** Management should have a process to verify job application information of all new employees. Screening procedures, including verification and background checks, should be developed for recruitment of permanent and temporary IT staff, and contractors, particularly for sensitive IT-related jobs or access level. Similar checks should be conducted for all staff, including contractors, at regular intervals throughout their employment, commensurate with the nature and sensitivity of their job functions as well as their access to critical systems. Management should be aware of changing personal circumstances of employees and contractors that may be indicative of potential increased incentives for system misuse or fraud. Further, it should establish processes and controls to mitigate risks related to employees' termination/resignation or changing responsibilities.

3.3.2. **Physical and Environmental Controls.** Physical security measures should be in place to protect computer facilities and equipment from damage or unauthorized access that can impair the confidentiality, integrity, and availability of information. Critical information processing facilities should be housed in secure areas such as data centers and network equipment rooms with appropriate security barriers and entry controls. Access to these areas should be restricted to authorized personnel only and upon presentation of proper identification and authentication process (i.e., ID cards, badges, biometrics, etc.). Moreover, a specific and formal authorization process should be employed for the removal of hardware and software from the premises.

Since the data center houses the BSFI's most critical information processing facilities, Management should fully consider the environmental threats (e.g., proximity to dangerous environment hazards) when selecting sites for data centers. Buildings should give minimum indication of their purpose, with no obvious signs identifying the presence of information processing facilities. Moreover, physical and environmental controls should be implemented to prevent, detect, and monitor environmental conditions which could adversely affect the operation of information processing facilities (e.g., fire, explosives, smoke, temperature, water, and dust). Equipment and facilities should be protected from power failures and electrical supply

interference by, for example, installing uninterruptible power supply (UPS) and backup generators. Management should ensure that these systems and devices regularly undergo preventive maintenance to ensure that they are in good working condition and operating as intended.

- 3.3.3. **Technical Controls.** Management should employ robust and multi-layered technical controls to ensure that the confidentiality, integrity, and availability objectives for information assets are met. These consist of various logical security controls, security tools, and technologies which provide defense against system compromise. Technical controls represent the technology factor in information security that should be working in tandem with the BSFI's policies, standards, and processes.

3.3.3.1. **Technology Design.** Management should consider information security and cyber resilience during the infrastructure build-up, systems development and product design. It should ensure that applicable standards and operating procedures are in place for all software, network configurations, and hardware connected to critical systems. Management should also understand the benefits and limitations of the technology that the institution uses and provide compensating controls when necessary. Management should also adopt mechanisms to continually assess whether processes, people, and technologies support the desired level of information security based on the BSFI's size, complexity, and risk profile.

3.3.3.2. **Identity and Access Management.** The BSFI should adopt a sound and systematic identity and access management program following the principles of least privilege and segregation of duties. Access rights and system privileges granted should be the minimum required for users to perform their job functions and responsibilities. No person, by virtue of rank or position, should have unrestricted and unauthorized access to confidential data, applications, system resources or facilities.

The BSFI should have an effective process to manage user authentication and access control consistent with the criticality and sensitivity of the information/system. The grant, modification, and removal of user access rights should be approved by the information/system owner prior to implementation. Information/system owners or business line managers should ensure that user access rights remain appropriate through a periodic user access re-certification process. Obsolete user accounts or inappropriate access rights should be disabled/removed from the systems in a timely manner.

Prior to granting access to systems, users should be required to sign an acceptable-use policy (AUP) to promote user awareness and accountability in conforming to security policies and procedures. The BSFI should have password standards in place to ensure that user passwords are not easily compromised (i.e., password syntax, validity, system-enforced password changes). Stronger authentication methods, such as the use of multi-factor authentication techniques, should be deployed for high-risk transactions (e.g., large value funds/wire transfers, enrollment of billers, systems administration functions).

Default user accounts defined in new software and hardware should either be disabled or changed and subject to close monitoring. Privileged access and use of emergency IDs should be tightly controlled as it gives the user the ability to override system or application controls. The necessary controls include:

- a. Formal approval process on a need-to-use or event-by-event basis;
- b. Prohibiting shared usage of privileged accounts/IDs;
- c. Logging and monitoring of activities performed;
- d. Proper safeguard of privileged and emergency IDs and passwords (e.g., kept in a sealed envelope and locked in a secure place inside the data center); and
- e. Change of privileged and emergency IDs' passwords immediately upon return by the requesters.

3.3.3.2.1. **Remote Access.** The BSFI, in line with business strategies and needs, may allow employees to connect remotely to the institution's network using either an institution-owned or a personally owned device (often referred to as "bring your own device" or BYOD). Management should ensure that such remote access is

provided in a safe, secure, and sound manner to manage attendant risks. At a minimum, the BSFI should establish control procedures covering:

- a. Formal authorization process for granting remote access;
- b. Risk-based authentication controls for remote access to networks, host data and/or systems, depending on the criticality and sensitivity of information/systems;
- c. Securing communication channels, access devices and equipment from theft, malware and other threats (i.e., encryption, strong authentication methods, data wipe capabilities, application whitelisting¹); and
- d. Logging and monitoring all remote access communications.

For BYOD, Management should fully understand the benefits in line with business goals/strategies as well as the risks in adopting BYOD policy. An effective mechanism should be in place to ensure that personal devices meet certain security standards, such as operating system version, patch levels, and anti-malware solutions, before these can be allowed to access the internal network.

3.3.3.3. **Network Security.** Management should adopt robust and multi-layered controls to prevent and detect unauthorized access, misuse, and other threats from entering and/or spreading into its internal computer networks and systems. Effective controls should be employed to adequately secure system and data within the network which include the following, among others:

- a. Grouping of network servers, applications, data, and users into security domains or zones (e.g., untrusted external networks, external service providers, or trusted internal networks);
- b. Adopting security policies for each domain in accordance with the risks, sensitivity of data, user roles, and appropriate access to application systems;
- c. Establishment of appropriate access requirements within and between each security domain;
- d. Implementation of appropriate technological controls to meet access requirements consistently;
- e. Monitoring of cross-domain access for security policy violations and anomalous activity; and
- f. Maintaining accurate network diagrams and data flow charts².

Commonly used tools and technologies to secure the network include firewalls, intrusion detection systems (IDS), intrusion prevention systems (IPS) and demilitarized zones, among others. As the network complexity as well as threats affecting the network evolve, the BSFI should continuously monitor and enhance its network security and systems to ensure that they remain secure, safe, and resilient.

Additional controls should be adopted for Wireless Local Area Networks (WLAN) implementations since these are inherently less secure than wired networks. Controls such as limiting of WLAN signals to authorized areas, physically securing wireless access points and formally approving installations of wireless devices/gateways and active monitoring of the WLAN environment should be employed on top of the usual network security controls. Management may also consider implementing network access control (NAC) systems to prevent recognition and connection of unauthorized or rogue devices into the network.

3.3.3.3.1. **Virtualization.** As BSFIs are increasingly leveraging on virtualization technologies to optimize existing hardware resources, reduce operating expenses and improve IT flexibility and agility to support business needs, additional security risks such as attacks on hypervisor integrity and lack of visibility over intra-host communications and virtual machine (VM) migrations are also rising. To address such risks,

¹ *Application whitelisting* is the maintenance and use of a list of applications and their components (e.g., libraries and configuration files) that are authorized to be present or active on a system according to a well-defined baseline.

² Network and data flow diagrams should identify hardware, software, and network components, internal and external connections, and types of information passed between systems to facilitate the development of a defense-in-depth security architecture.

Management should extend security policies and standards to apply to virtualized servers and environment. Likewise, it should adopt the following control measures:

- a. Hypervisor hardening with strict access controls and patch management;
- b. Inspection of intra-host communications {traffic within VM environments} and ensuring that security control measures are implemented for confidential/sensitive data stored in VMs; and
- c. VM creation, provisioning, migration, and changes should undergo proper change management procedures and approval processes similar to deployment of physical network/system devices and servers.

The BSFI may also consider implementing next generation firewalls that can restrict access more granularly and prevent virtualization-targeted attacks that exploit known VM vulnerabilities and exploits.

- 3.3.3.4. **Application Security.** Management should ensure that all applications, whether developed in-house or acquired off-the-shelf, have appropriate controls commensurate to the sensitivity and criticality of applications. Core banking applications as well as other applications considered as mission-critical (e.g., loans, general ledger and treasury systems) should have embedded security control features to maintain information confidentiality, integrity and availability. Secure coding practices which consider security control requirements early into the development phase should be incorporated in the BSFI's application systems development and acquisition policies and procedures. New applications, including subsequent enhancements, should be adequately tested using various testing methodologies (e.g., penetration tests, vulnerability assessments, and application security tests) before loading into production. In case third parties were engaged to develop the applications, Management should exercise adequate oversight to ensure that the level of risk management and security controls/standards is consistently applied.

Security controls within applications should have adequate access and authentication controls, audit trails and logs, and logical controls appropriate to the applications' business purpose and function (e.g., maker/checker functionalities, transaction limits and alerts). Application systems reviews, penetration testing and vulnerability assessments should be periodically conducted to ensure that the applications meet the desired level of security.

- 3.3.3.5. **Data Security.** The BSFI should have information classification strategy guidelines and institute appropriate set of controls and procedures for information protection in accordance with the classification scheme. Information should be protected throughout its life cycle from handling, storage or data-at- rest, transmission or data-in-transit, up to the disposal phase.

- 3.3.3.5.1. **Data-at-Rest.** Policies, standards, and procedures as well as risk management controls must be in place to secure the BSFI's information assets, whether stored on computer systems, physical media, or in hard- copy documents. The level of protective controls shall depend on the sensitivity and criticality of the information. Sensitive information such as system documentation, application source code, and production transaction data are expected to have more extensive controls to guard against alteration or data leakage (e.g., integrity checkers, cryptographic hashes, data leakage prevention systems). Management should likewise implement appropriate controls over information stored on portable devices such as laptops, smart phones, and tablets taking into account their susceptibility to lost or theft. Applicable risk mitigation controls include data encryption, host-provided access controls, homing beacons, and remote wiping or deletion capabilities, among others.

Considering the unique risk dimensions of storing data in cloud computing platforms, Management should fully understand the nature of the cloud technology in line with business requirements and satisfy themselves as to the level

of security (e.g., how access is controlled and how information is retrieved) and compliance to data privacy and other relevant rules and regulations. Information security and accountability still rests with the institution's Management, hence, it should exercise effective oversight over the cloud service provider in terms of adherence to security, performance and uptime, and back-up and recovery arrangements contained in the contract/agreement.

3.3.3.5.1.1. **Database security.** The BSFI should adopt policies, standards, and procedures to adequately secure databases from unauthorized access, misuse, alteration, leakage and/or tampering. Considering their criticality, sensitivity and business impact, access authorizations to databases should be tightly controlled and monitored. Databases should be configured properly and securely with effective preventive and detective controls such as encryption, integrity checkers, logs and audit trails, among others.

3.3.3.5.1.2. **Data-in-transit.** Data transfers are commonly done through physical media or electronic transmission. Policies, standards, and procedures should be in place for maintaining the security of physical media containing sensitive information while in transit, including to off-site storage, or when shared with third parties. These include contractual requirements incorporating risk-based controls, accreditation process for carriers/couriers, packaging standards, encryption of sensitive information, tracking of shipments, and non-disclosure agreements, among others.

Electronic transmission may be done using various channels such as e-mail, file transfer protocols, secure shell, dedicated line, short message service, and the internet. Management should develop policies and procedures and implement appropriate safeguards depending on the channel used. When transmitting sensitive information over a public network, the institution may use encryption controls and techniques such as secure e-mail protocols, secure file transfer protocol (SFTP), and secure socket layer (SSL) certificates to protect against interception or eavesdropping.

3.3.3.5.2. **Removal, Transfers and Disposition of Assets.** Procedures for the destruction and disposal of media containing sensitive information should be risk-based relative to the sensitivity of the information and the type of media used to store the information. Disposal techniques that the BSFI may implement include deletion, overwriting, degaussing¹, destruction of the media. Management should be mindful about residual data being stored in computer-based media as well as dumpster-diving attacks in paper-based information in deciding the best disposal strategy for sensitive information assets. BSFIs should consider applicable Bangko Sentral regulations as well as laws, rules and regulations in developing policies and procedures on disposal of records/media.

3.3.3.6. **Malware Protection.** Malware threats continue to be a serious concern given their rapid proliferation and advanced capabilities to disrupt operations, corrupt data, and conduct unauthorized transactions. Zero-day exploits and other advanced malwares have the ability to penetrate various access points within the BSFI's network and evade traditional signature-based anti-malware systems and network monitoring controls. To mitigate such risks and ensure resilience against malware threats, Management should adopt layered and integrated anti-malware strategy, including data integrity checks, anomaly detection, system behavior monitoring, and enhanced employee security awareness training programs.

¹ *Degaussing* is a procedure that reduces the magnetic flux to virtual zero by applying a reverse magnetizing field. Also called demagnetizing.

At a minimum, Management should apply the "Least Privilege" principle in granting access to all systems and services and mandate safe computing practices for all users. Other preventive measures include installation and timely update of anti-malware software provided by reputable vendors, periodic vulnerability scanning, and effective patch management procedures for all critical systems and applications. To address the more sophisticated forms of malware, Management should consider adopting advanced security solutions such as signature-less anti-malware solutions capable of analyzing abnormal behavioral patterns in network and system traffic flows. Likewise, application whitelisting which allows only specified programs to run and/or sandboxing technologies which can inspect incoming traffic such as e-mail attachments without compromising the production environment can be employed.

As malware sophistication and capabilities evolve, Management should continuously monitor changes in technologies, threat profiles and the overall operating environment to address emerging risks. It should likewise closely coordinate with its technology vendors and relevant information sharing groups for appropriate remediation procedures.

3.3.3.7. **Encryption.** Encryption, when properly designed, managed, and implemented, can serve as a key control in securing communications, information, and data storage. Management should adopt a sound encryption program covering the following elements:

- a. Encryption type, level and strength commensurate to the sensitivity of the information based on the institution's data classification policy;
- b. Effective key management policies and practices to properly safeguard the generation, distribution, storage, entry, use, and archiving of cryptographic keys; and
- c. Periodic review and testing to ensure that encryption methods deployed still provide the desired level of security vis-a-vis changes in technology and threat landscape.

3.3.3.8. **Integration with IT Processes.**

3.3.3.8.1. **Systems Development and Acquisition.** Security requirements and considerations should be deeply embedded into the BSFI's systems development and acquisition processes. Involvement of internal audit and information security personnel in the development or acquisition activities should be clearly defined as a means to verify the adequacy of the control and security requirements as they are developed and implemented.

Aside from business functionalities, security requirements relating to system access control, authentication, transaction authorization, data integrity, system activity logging, audit trail, security event tracking, and exception handling should be clear and specific. The information and/or process owners should check security requirements and conduct user acceptance tests prior to approval of systems to be loaded into the production environment.

Further, BSFIs should maintain separate environments for their development, testing, and production activities respectively. In line with this, programmers/developers should have no access to the production environment. Lastly, strict segregation of duties between developers/programmers and IT operations should be upheld.

3.3.3.8.2. **Change Management.** The BSFI should have an effective and documented process to introduce changes into the IT environment in a safe and secure manner. Such changes should be controlled as to requirements definition, authorization and approvals, testing procedures, and audit trails. Moreover, the process should incorporate review of the impact of changes to the effectiveness of security controls.

3.3.3.8.3. **Patch Management.** Management should adopt a patch management process to promptly identify available security patches to technology and software

assets, evaluate criticality and risk of patches, and test and deploy patches within an appropriate timeframe.

- 3.3.3.8.4. **Vendor Management and Outsourcing.** Management should conduct appropriate due diligence and consider information security in selecting third party service providers (TPSPs). The BSFI should ensure that effective oversight processes are in place to monitor the activities of TPSPs. Contracts should sufficiently detail information security requirements, particularly for TPSPs that store, transmit, process, or dispose of customer information. Mechanisms should be in place to properly monitor the performance of third party service providers to confirm whether sufficient level of controls is maintained. Considering that TPSPs may be a source of cyber-risks, Management should properly assess cyber-risk exposures from TPSPs in order to proactively adjust their cyber-risk management

- 3.4. **Detection.** Management should design and implement effective detection controls over the BSFI's networks, critical systems and applications, access points, and confidential information. Detection controls provide the institution with alerts and notifications for any anomalous activities within its network that can potentially impair the confidentiality, integrity, and availability of information assets. Early detection is critical to the BSFI's incident response and recovery procedures as it allows sufficient lead time to institute countermeasures to address impending attacks and contain associated impacts. The detection capabilities are largely a function of people, process, and technology that enable continuous monitoring of the institution's internal networks, systems, applications, and databases.

The level and maturity of the BSFI's detection capabilities should be commensurate to its IT profile classification and operating environment. The selection and design of detection controls largely depends on business priorities and overall security strategy. Detection controls which Management may employ include intrusion detection systems (IDS), virus/malware detection, honeypots, system alerts/notifications, and security incident and event management (SIEM) system. For moderate to complex BSFIs, detection controls are expected to be largely automated to facilitate real-time or near real-time analysis of events such the use of SIEM, IDS, and other technology-based detection systems.

At a minimum, all BSFIs should be able to establish baseline profile of system activity or condition and data flows across the layers of their infrastructure to facilitate monitoring and detection of anomalous activity. Likewise, metrics should be defined for systems, applications and network to determine indicators of possible compromise. For instance, access to a highly-sensitive system beyond office hours or failed log-in attempts of privilege user accounts should prompt real-time or near real-time alerts and notification to concerned security operations personnel.

- 3.4.1. **Log Management.** Log files can be analyzed for real-time or near real-time detection of anomalous activities, facilitate subsequent investigation of security incidents and can serve as forensic evidence for the prosecution of fraudulent activities. Thus, Management should put in place adequate security controls to prevent unauthorized access, modification and/or deletion of log files. Depending on the criticality of information contained in the log files, Management should implement the following controls to secure the integrity of log files:

- a. Encrypting log files containing sensitive data, where feasible;
- b. Ensuring adequate storage capacity to avoid gaps in log generation;
- c. Restricting access and disallowing modification to log files. Attempts to tamper with log files should prompt activation of system alarms/notifications; and
- d. Securing backup and disposal of log files.

- 3.4.2. **Layered Detection.** In designing the BSFI's detection controls and monitoring capabilities, Management should, to the extent feasible, adopt a layered or defense-in- depth approach to ensure that a failure in one control would be compensated by another control. This approach effectively delays or disrupts an attacker's ability to progress within the attack sequence. Tools such as attack trees, event trees, and kill chains may be utilized to enable swift identification and remediation of attacks as they occur.

- 3.5. **Response.** The response phase is triggered upon confirmation of an occurrence of a cyber-attack or security incident affecting the BSFI and its customers. With the growing incidence of sophisticated cyber-crimes and threats, Management should develop comprehensive, updated, and tested incident response plans supported by well-trained incident responders, investigators, and forensic data collectors. Through adequate response capabilities,

Management should be able to minimize and contain the damage and impact arising from security incidents, immediately restore critical systems and services, and facilitate investigation to determine root causes.

3.5.1. **Incident Response Plan and Procedures.** Management should develop and implement a formal incident response plan to address identified information security incidents in a timely manner. The incident response plan should:

- a. Provide a roadmap for implementing an incident response process appropriate to the nature, size, and complexity of the institution;
- b. Describe the structure and organization that supports the incident response process;
- c. Classify incidents, define reportable incidents, and escalation protocols;
- d. Define metrics for assessing the incident response process; and
- e. Define resources and management support needed to effectively maintain and continuously improve the incident response process.

3.5.2. **Incident Management Process.** Incident handling should follow a well-defined and documented incident management process which sufficiently details the steps from incident analysis and triage assessment, impact mitigation and containment up to testing and continuous improvements.

3.5.2.1. **Incident Analysis and Triage Assessment.** Reported incidents should be investigated to confirm their occurrence and classification. Incidents should be categorized or classified in a manner that enables appropriate prioritization of response and recovery efforts. The category of an incident should guide protocols for communicating to internal and external stakeholders.

3.5.2.2. **Impact Mitigation and Containment.** Upon discovery of an information security incident, the BSFI should seek to contain the damage, mitigate its effects, and eradicate the cause of the incident. Containment measures should be implemented to prevent further harm to the BSFI and/or its customers. Strategies for containment can vary between organizations but typically include the following:

- a. Isolation of compromised systems;
- b. Remediation and recovery of compromised systems;
- c. Collection and preservation of evidence; and
- d. Communication with affected parties (e.g., primary regulator, information-sharing organizations, law enforcement authorities, customers).

3.5.2.3. **Testing and Continuous Improvement.** Management should define a process for periodically reviewing the incident response plan and updating it based on the BSFI's experience from current and previous incident response activities, including periodic testing exercises.

3.5.3. **Incident Response Teams.** The incident response plan should identify in advance the personnel who will be tasked to respond to an information security incident and clearly define their roles and responsibilities. Organizing a team and assigning responsibilities during an actual incident is likely to cause confusion and may limit the ability of the BSFI to effectively execute response and recovery efforts. In this regard, BSFIs should set-up and organize a formal security incident response team (SIRT) tasked to perform, coordinate, and support responses to security incidents and intrusions. Typical SIRT membership includes individuals with varied backgrounds and different areas of expertise including management, legal, public relations, information security, and information technology.

3.5.4. **Crisis Communication and Notification.** The plan should be adequately communicated to appropriate internal and external stakeholders. The BSFI should establish and communicate standard procedures for reporting possible information security incidents to a designated officer or organizational unit.

Concerned BSFIs should promptly notify the Bangko Sentral of any confirmed IT-related fraud cases or major security breaches, pursuant to Sec. 148. Appropriate law enforcement authorities should also be notified in situations involving criminal violations requiring immediate attention. Incidents involving unauthorized disclosure of sensitive personal information should comply with notification rules set by the National Privacy Commission. Customers should also be notified when warranted.

- 3.5.5. **Forensic Readiness.** Management should implement appropriate controls to facilitate forensic investigation of incidents. Policies on system logging should be established covering the types of logs to be maintained and their retention periods. Applicable Bangko Sentral regulations as well as laws, rules, and regulations on records retention should be complied with. Where a follow-up action against a person or organization after an information security incident involves legal action, evidence shall be collected, preserved, and presented to conform to the relevant rules for evidence.

Management should define in the response plan a systematic process for recording and monitoring information security incidents to facilitate investigation and subsequent analysis. Adequate documentation should be maintained for each incident from identification to closure. Facts about the incident, operational impact, estimated cost, investigation findings, and actions taken by the BSFI should be consistently documented. Automated means of reporting and tracking of incidents may be implemented for analysis and preparation of reports to support decision-making.

- 3.5.6. **Outsourcing.** For a BSFI without in-house technical expertise, outsourcing of functions related to security incident response including forensic investigations, can be a viable option. In such instances, Management should require the service provider to strictly adhere to the BSFI's policies and standards and ensure confidentiality of data.

- 3.6. **Recovery.** The recovery phase encompasses both the resumption of activities at a level which is considered "good enough for a certain period of time" and full recovery, i.e., an eventual return to full service. The BSFI should be able to establish back-up facilities and recovery strategies to ensure the continuity of critical operations. During recovery phase, Management should ensure that information processed using back-up facilities and alternate sites still meet acceptable levels of security.

- 3.6.1. **Business Continuity Management.** Management should develop and implement a formal incident recovery plan to restore capabilities or services that are affected by information security incidents in a timely manner. This can be achieved by incorporating scenarios related to information security (e.g., data breach, malware outbreak, denial of service) in its business continuity and disaster recovery plans. Refer to Sec. 149 for further guidance on Business Continuity Management (BCM).

- 3.6.2. **Communication Plan.** A communication plan for information security incidents should be incorporated in the incident recovery plan to facilitate escalation for appropriate management action and to help manage reputation risk. Incidents that lead to publicly visible disruption to BSFI services should be given utmost attention. Timely notification should be given to all relevant internal and external stakeholders (e.g., employees, customers, vendors, regulators, counterparties, and key service providers, media and the public) following a disruption.

Management should consider alternate methods of communication and preparation of predetermined messages tailored to a number of plausible disruption scenarios to ensure various stakeholders are timely, consistently, and effectively informed. Refer to Sec. 149 for further guidance on crisis management.

- 3.6.3. **Cyber Resilience.** Management should consider the potential impact of evolving cyber events into the BSFI's business continuity planning and institute adequate cyber resilience capabilities. Given the unique characteristics of cyber-threats and attacks, traditional back-up and recovery arrangements adopted may no longer be sufficient. In some instances, it may even exacerbate the damage to BSFI's network, operations, and critical information assets. Hence, Management must consider cyber-related attacks and incidents in the BCM and recovery processes to achieve cyber resilience.

- 3.6.3.1. **Business Impact Analysis/Risk Assessment.** Management should consider the impact of cyber-threat scenarios during the Business Impact Analysis/Risk Assessment (BIA/RA) phase in conjunction with the ongoing information security risk assessment process. The BSFI should take into consideration a wide-range of cyber-threat scenarios perpetrated from diverse threat sources (e.g., skilled hackers, insiders, state-sponsored groups) which seek to compromise the confidentiality, availability, and integrity of its information assets and networks. Cyber-risks and threats such as malware, distributed denial of service (DDoS) attacks, advance persistent threats (APTs), among others, should be considered in the BIA/RA process.

- 3.6.3.2. **Defensive Strategies.** Depending on the results of its risk assessments and cybersecurity profile, the BSFI may need to deploy defensive strategies ranging from basic to highly advanced technologies to

promote cyber resilience, such as, defense-in-depth or layered controls, reducing attack surfaces, virtual technologies, air-gap facilities and threat intelligence feeds, among others.

- 3.6.3.3. **Recovery Arrangements.** Depending on IT and operations risk profile and complexity, Management should consider adopting innovative recovery arrangements that address the unique risks arising from cyber-threats. These include the use of non-similar facility, cloud-based disaster recovery solutions and pre-arranged third party forensic and incident management services.

- 3.7. **Assurance and Testing.** Management needs to continually assess and test controls and security measures implemented under prevent, detect, respond and recover phases to ensure that these are effective and working as intended. Likewise, a comprehensive, systematic and layered testing and assurance program covering security processes and technologies should be in place. This is to ensure that the ISP is on track in providing appropriate level of information security commensurate to the BSFI's IT profile classification. This phase also ensures that the ISSP and ISP remain effective vis-a-vis the fast-evolving cyber-threat landscape.

- 3.7.1. **Testing Program.** Given the dynamic nature of information security risks, Management should continually ascertain that the ISP is operating as expected and reaching the intended goals. The scope and depth of testing generally depend on the level of confidence that the Board and Senior Management intend to place on the program. Management should establish a written testing and evaluation plan that assesses the effectiveness of system design and operation, including the integration of security controls, vis-a-vis the level of assurance desired by the Board and Senior Management. At a minimum, the testing plan should have the following key elements:

- a. Scope, timing, and frequency of testing;
- b. Independence and capability of the testing personnel and review team;
- c. Criteria used to ascertain whether the results are acceptable; and
- d. Reporting process to the Board and Senior Management.

- 3.7.2. **Types of Tests and Evaluations.** Considering that no one type of assessment can provide a complete representation of the BSFI's information security posture, Management should employ a variety of effective testing methodologies and practices in order to validate the overall effectiveness of the ISP. Some of the more common types of security assessment/testing with corresponding objectives, brief description and other details, in order of increasing complexity, are as follows:

- a. Self-Assessment - an activity conducted by the specific business line or department that typically captures their awareness of the level of risk and effectiveness of controls concerning their own business processes and functions. Since these are performed by the concerned business units themselves, an independent review process should occur subsequent to the conduct of self-assessment for validation and consistency across the entire BSFI.
- b. Security Audit/Review and Compliance Check - is commonly performed by the BSFI's IT auditors, security personnel, and compliance function, respectively, to assess compliance to relevant security policies, standards, and procedures. Internal or external auditors review all aspects of the ISP to determine its overall effectiveness in achieving the desired security results or outcome. Auditors must have the necessary background, training, experience, and independence to effectively discharge their tasks and responsibilities.
- c. Vulnerability Assessment (VA) - refers to the identification of security vulnerabilities in systems and network usually through the use of automated vulnerability scanners. Frequency of the performance of vulnerability scans should be determined based on assessment of risk and criticality of systems or information stored on each system. High risk vulnerabilities uncovered during VA exercises should be remediated within a reasonable timeframe.
- d. Penetration Testing (PT) - involves subjecting a system or network to simulated or real-world attacks that exploit vulnerabilities under controlled conditions. Depending on the test objectives and scope, the BSFI may use penetration testing to assess potential business impact, the level of security, risk management processes and controls as well as the knowledge of concerned personnel in the organization in identifying, detecting, and responding to attacks.

For BSFIs providing digital/electronic, financial services, VA and PT should be performed by an external party at least annually.

- e. **Scenario-Based Testing** - constitutes a wide range of scenarios, including simulation of extreme but plausible events such as targeted cyber-attacks in testing the BSFI's response, resumption and recovery practices, including governance arrangements and communication plans. To ensure robustness of test scenarios, cyber threat intelligence and threat modeling should be utilized to the extent possible to mimic actual cyber-threats and events.
- f. **Compromise/Breach Assessment**- involves the placement of sensors/tools within the network to actively probe network traffic and system activities to detect, alert, and potentially mitigate malware intrusions as they occur. This type of assessment addresses advanced malwares and threats with capabilities to evade traditional monitoring systems. Complex BSFIs should conduct regular compromise/breach assessment exercises, on top of other types of tests, to enhance the level of assurance on their security posture as well as their overall situational awareness.
- g. **Red-Teaming Exercise** - a more in-depth type of penetration testing which continually challenges the organization's defenses and controls against cyber- attacks. The red team is composed of highly-trained specialists, acting on adversarial mode, which may be the BSFI's own independent employees or third party experts. The end objective is to improve the state of readiness of the entire organization in cases of cyber-attacks.

4. CYBER THREAT INTELLIGENCE AND COLLABORATION

- 4.1. **Situational Awareness and Threat Monitoring.** In response to rapidly-evolving, sophisticated, and coordinated cyber-attacks targeting financial institutions, BSFIs need to enhance situational awareness as well as their threat monitoring capabilities. Situational awareness is a state whereby the BSFIs' Board and Senior Management are fully aware of the internal and external threat environment as it relates to their IT risk and cyber-risk profiles, operating complexities and business models. Situational awareness entails gathering and maintaining robust threat intelligence about the proficiencies, tactics, and motives of malicious actors/attackers that enable BSFIs to institute appropriate countermeasures quickly. A keen sense of the threat landscape, both from internal and external sources, would greatly help BSFIs in adjusting their ISSP and ISP to achieve cyber- resilience. BSFIs should establish a systematic process of gathering, analyzing, and monitoring threat information for actionable intelligence, timely insights, and proactive response. As gathered from Bangko Sentral 's surveillance and monitoring activities, below are some of the top cyber-threats that BSFIs should be wary about with the corresponding prescribed countermeasures/controls:

Threat Description	Prescribed Countermeasures/Controls
Card Skimming - refers to the illegal copying of information from the magnetic stripe of a credit or ATM card to gain access to accounts. This type of fraud usually results to financial losses and unauthorized charges to the customers.	As required under Sec. 148 , BSFIs should migrate their entire payment card network to the EMV technology. This is to address the vulnerabilities of magnetic stripe cards from card skimming fraud. Pending full migration to EMV, BSFIs should implement mitigating controls such as those specified under Bangko Sentral Memorandum No. M-2014-040 dated 03 October 2014 on Card Fraud and skimming attacks.
Distributed Denial of Service (DDoS) Attack - makes use of the capacity limitation of enterprise networks, systems or applications with extreme traffic loads or requests that impair their availability to legitimate users.	BSFIs should implement multiple layers of control to prevent, detect, correct, monitor, and analyze system and network anomalies arising from DDoS attacks. These include deployment of on-premise and/or cloud-based solutions, close coordination with internet service providers (ISPs) and hosting companies, as well as having a robust and reliable back-up system. Incident response plans should cover response and recovery procedures for DDoS attacks. In some cases, a DDoS attack is used as a diversionary tactic, hence, BSFIs should be on heightened alert for any signs of infiltration or presence of malware across their IT environment during and after such incident.

Phishing Attacks - involve tricking customers into giving sensitive information through fraudulent emails or websites.	Employee and customer awareness campaigns and education programs are key elements in addressing phishing attacks since these attacks specifically exploit BSFIs' employees, officers and customers. BSFIs should adopt multi-factor authentication for high-risk systems/transactions in order to limit the ability of attackers to consummate the fraud. Further, BSFIs should adopt security measures and mitigating controls prescribed under Memorandum No. M-2015-025 dated 22 June 2015 on Guidance on Management of Risks Associated with Fraudulent E-mails or Websites.
Ransomware and other malwares - refer to malicious software that compromises the confidentiality, availability, and integrity of information systems, networks and data. For ransomware, data or applications are encrypted by the attacker to prevent users from accessing their own data. Only when users pay the "ransom" will these information or systems be released.	On top of the security controls and measures under Item 3.3.3.6 on malware prevention prescribed above, BSFIs, specifically those confronted with ransomware attacks should refrain from paying or communicating with the malicious actor as this does not guarantee that ransomed and/or encrypted files will be released. To mitigate the potential catastrophic impact of ransomware attacks, BSFIs should ensure that adequate back-up and recovery procedures for critical systems and data, including periodic testing to check the integrity thereof, are in place. Because back-ups may also be subject to attacks, BSFIs should consider supplementing existing practices with cloud-based back-ups and/or back-ups using removable media or air-gapped facilities.
Advanced Persistent Threats (APT) - are highly-sophisticated attacks which primarily target a specific institution or industry for terrorist aims, corporate espionage or massive fraud schemes. APTs often involve integrity breach wherein core data, systems, and network are compromised and corrupted once an attacker gained foothold and established persistent presence in the target environment.	These types of attacks are generally more destructive compared to the other cyber-threats since the threat actors are highly skilled, motivated, and determined to infiltrate and exploit vulnerabilities on stealth mode. As such, Management should adopt defense-in-depth strategy in preventing and detecting APTs. Likewise, complex BSFIs that are more vulnerable to these types of threats should consider deploying automated and advanced security tools, technologies and methods such as the use of anti-malware solutions, behavior-based fraud management systems and monitoring tools with machine-learning capabilities, among others. These technologies should be supported by 24x7 monitoring through a mature SOC. High-risk system should have robust security controls and closely monitored for any anomalous or suspicious activities. A strong security culture should likewise be instilled across the organization as a first line of defense.

4.1.1. **Security Operations Center.** In light of the growing cyber-threat concerns affecting BSFIs, the need for centralized visibility, continuous monitoring, and rapid response and recovery procedures is increasingly heightened. Hence, centralizing security operations through a security operations center (SOC), equipped with automated security monitoring tools, defined processes and highly-trained personnel, enables BSFIs to keep pace with the tactics of advanced threat actors. Complex BSFIs should put in place an SOC tasked to provide round-the-clock monitoring and real-time analysis of security incidents and cyber-related events.

An SOC is typically organized into three levels or tiers, with Tier 1 responders serving as the frontlines to monitor security endpoints and perform incident triage procedures in line with the institution's incident response plans and procedures. Depending on incident classification, security events are then escalated to Tier 2 and Tier 3 responders accordingly to conduct deep-dive analysis and investigation to quickly remediate, contain and recover from the incident. The SOC's major functions commonly cover detect, respond, and recover phases in the information security cycle. These include network, host, and application activity monitoring; forensic investigation; threat analysis and modeling; and engagement with security service providers and information sharing groups. The BSFI should adopt adequate policies and procedures in managing the SOC which should be integrated into its governance mechanisms, business and IT operations, incident response and BCM processes.

Considering that it may be difficult for some organizations to establish a mature and fully-operational SOC with the requisite skills, expertise and tools, the BSFI may opt to outsource some or all of its SOC functions to a third party service provider. This may be under a managed security service arrangement either

on-premise, off-premise or through cloud computing platforms. In this regard, Management should exercise adequate oversight, due diligence and other risk management controls, and comply with existing Bangko Sentral regulations on outsourcing and cloud computing.

- 4.1.2 **Emerging Technologies and Innovation.** Emerging technologies and innovation are continuously being introduced in the market resulting to a dynamic operating environment for BSFIs. These include distributed ledger technologies (DLT), cryptocurrencies, big data and internet of things (IOT), among others. These technologies, if prudently harnessed, can significantly increase market share, improve customer experience, enhance security, and promote financial inclusion.

Prior to adopting these emerging technologies, Management should fully understand the mechanics, implications to consumer protection, money-laundering and overall security posture as well as inherent risks associated with these new technologies. In cases where applicable regulations/requirements are unclear, BSFIs should consult the Bangko Sentral prior to implementation.

- 4.2. **Information Sharing and Collaboration.** With the stealthier, sophisticated and advanced forms of cyber-threats and attacks confronting the financial services industry, BSFIs should have a collective, coordinated, and strategic response through information sharing and collaboration. Information sharing allows BSFIs to enhance threat intelligence/situational awareness that enable quick identification, prevention, and response to emerging and persistent threats. In some cases, BSFIs may need to cooperate with concerned government/regulatory bodies, law enforcement agencies and third party providers to prosecute cyber-criminals, activate government incident response plans or issue warnings/advisories to the public. The extent, breadth, and nature of information sharing activities of BSFIs largely depend on their maturity and capabilities. Moderate to Complex BSFIs should actively engage in information sharing organizations and fora within the financial services industry.

At a minimum, BSFIs should define information sharing goals and objectives aligned with their ISSP and ISP. Further, BSFIs should formulate policies and procedures on information sharing activities within and outside their organizations, taking into consideration the following:

- a. Obtaining Board and Senior Management approvals prior to joining information sharing groups/communities;
- b. Listing/identifying threat information (i.e. indicators of compromise (IOC), tactics, techniques and procedures (TIPs), security alerts, etc.) that can be shared with trusted parties;
- c. Establishing processes to sanitize/anonymize threat information that may contain sensitive/confidential data; and
- d. Ensuring compliance with applicable laws, rules, and regulations (e.g. data privacy and bank secrecy laws).

- 4.3. **Continuous Improvement.** The BSFI should integrate continuous improvements in its ISSP and ISP to maintain an effective security posture amidst changing threat landscape and technological developments. Lessons learned from their own experiences as well as from other BSFIs/organizations should be incorporated in further enhancing its capabilities to identify, assess, and manage security threats and vulnerabilities. A holistic and systematic approach should be adopted in assessing the BSFI's security posture, supported by robust and effective metrics, to ensure that security program, initiatives and efforts are moving in the right direction. The improvement process should cover all aspects of ISRM, people, policies, standards and procedures, processes and technology which should ultimately result to ongoing cyber-resilience.

IT RISK MANAGEMENT STANDARDS AND GUIDELINES

Area: Project Management/Development, Acquisition and Change Management (Appendix to Sec. 147-Q/145-S/142-P/126-N (Purpose and Scope and IT Risk Management System))

1. INTRODUCTION

- 1.1. Because technology is constantly evolving, Management of BSFIs should periodically assess their uses of IT as part of overall business planning. Such an enterprise-wide and ongoing approach should be formalized in the IT strategic plan to help ensure that all major IT projects are consistent with its overall strategic goals.
- 1.2. As part of their strategic goals, BSFIs may need to constantly introduce new or enhanced products and services, improve systems and processes and implement updates and innovations in IT to secure and manage voluminous information and maintain their competitive position. This necessity may oftentimes result in initiating IT projects¹; which may be in the form of internal or external development of software applications or systems, acquisition and/or implementation of new or enhanced hardware, software, infrastructure or services with or without the help of third party providers
- 1.3. IT projects, when managed improperly, often result in late deliveries, cost overruns, or poor quality applications. Inferior applications can result in underused, insecure, or unreliable systems. Retrofitting functional, security, or automated-control² features into applications is expensive, time consuming, and often results in less effective features. Therefore, BSFIs should carefully manage IT-related projects to ensure they meet organizational needs on time and within budget.

2. ROLES AND RESPONSIBILITIES

- 2.1. The size and complexity of a project dictates the required number and qualifications of project personnel. Duties may overlap in smaller organizations or lower-risk projects; however, all projects should include appropriate segregation of duties or compensating controls.
- 2.2. **Board of Directors (Board) and Senior Management.** The BSFI's Board and senior management should review, approve, and monitor IT projects that may have significant impact on its operations, earnings or capital. They are responsible to ensure that IT projects support business objectives and adequate resources are available to complete these projects. Consequently, they should establish adequate policies and strategies to achieve these and ensure that risks related to IT projects are managed appropriately.

Senior management is expected to have more knowledge and involvement in the day-to-day operations of these IT projects to critically evaluate the design and oversee the related operation and activities. They should ensure that IT projects are coordinated and undertaken in adherence to appropriate policies, standards, and risk management controls. They should periodically inform the Board and/or IT Steering Committee of the IT initiatives and the related risks that these may pose to the BSFI. They should also review, approve, document and report deviations from established policies and standards.

- 2.3. **Quality Assurance.** An independent party (e.g., the quality assurance function, the TRM function or the technology audit team), who is not involved in the project development, should conduct a quality assurance review of major IT-related projects, with the assistance of the legal and compliance functions, if necessary. This review is to ensure compliance with the project life cycle³ methodology, other internal policies, control requirements, regulations and applicable laws.

3. PROJECT MANAGEMENT STANDARDS AND METHODOLOGY

- 3.1. **Project Management.** The BSFI should establish a general framework for management of major technology-related projects. This framework should, among other things, specify the project management methodology to be adopted and applied to these projects. The methodology should cover, at a minimum, allocation of responsibilities, activity breakdown, budgeting of time and resources, milestones, check points, key dependencies, quality assurance, risk assessment and approvals.

A BSFI that needs to coordinate multiple IT projects should establish standards for coordinating and managing the projects from an enterprise-wide perspective. The standards should, at a minimum, include guidelines for project prioritization, resource coordination and progress reporting.

¹ An IT project is a task involving the acquisition, development or maintenance of a technology product.

² Automated controls are software routines designed into programs to ensure the validity, accuracy, completeness and availability of input, processed and stored data.

³ Project life cycle refers to a logical sequence of activities to accomplish a project's goals or objectives.

- 3.2. **Project Methodology.** The BSFI should adopt and implement a full project life cycle methodology governing the process of developing, implementing and maintaining major computer systems. In general, this should involve phases of project initiation, feasibility study, requirement definition, system design, program development, system and acceptance testing, training, implementation, operation and maintenance.

The project life cycle methodology should define clearly the roles and responsibilities for the project team and the deliverables¹ from each phase. It also needs to contain a process to ensure that appropriate security requirements are identified when formulating business requirements, built during program development, tested and implemented.

4. PROJECT PLANNING AND INITIATION

- 4.1. A formal project committee, to ensure the development of well-structured applications, should be established with clear details of its terms and reference. The committee should at least consist of the following representatives:
- a. Senior management, to provide strategic direction and ensure full commitment;
 - b. User departments, to ensure that the application design meets their requirements;
 - c. Internal audit department, to act as an independent party to ensure adequate controls are diligently applied at all times. However, internal audit participation should only be on an advisory capacity; and
 - d. IT department, to provide technical knowledge and skills.
- 4.2. A feasibility study should be performed to identify the expected costs and benefits of developing a system, and also to decide either to utilize internal resources or to outsource to a vendor. In case of outsourcing, the responsibility of senior management does not diminish in ensuring that a well-designed application is developed. Senior management maintains the responsibility for ensuring that minimum controls are in place and are in accordance with the BSFI's standards.
- 4.3. When management proposes a new hardware, software or IT solution and/or changes to existing ones, it should ensure that functional, operational and regulatory requirements are accurately identified and clearly detailed in request for proposals (RFP²) or invitations-to-tender (ITT) that it distributes to vendors or third-party service providers (TSP) in the bid solicitation process. Moreover, relevant security requirements should be clearly specified before a new system is developed or acquired. A review should also be conducted to ensure an appropriate balance between security and other objectives (ease-of-use, operational simplicity, ability to upgrade, acceptable cost, etc.) is achieved.
- 4.4. During the development and acquisition of new systems or other major IT projects, project plans should address issues such as – a) business requirements for resumption and recovery alternatives; b) information on back-up and storage; c) hardware and software requirements at recovery locations; d) BCP and documentation maintenance; e) disaster recovery testing; and f) staffing and facilities. Likewise, during maintenance, where there are changes to the operating environment, business continuity considerations should be included in the change control process and implementation phase.
- 4.5. Proper planning should be employed to ensure IT projects meet their objectives. Project control systems should be employed to monitor specific target completion dates for each task of systems development against original targets. Periodic reports to senior management such as, project priorities and status, resource allocations, target deviations and budgets, should be in place to measure project effectiveness.

5. SYSTEMS DEVELOPMENT

- 5.1 Development projects involve the creation of applications, integrated application systems and other critical softwares. Software development projects are completed in-house, through outsourcing, or by a combined approach.

To manage this type of projects, the BSFI should establish development standards that, at a minimum, address project management, system control, and quality assurance issues. Project management standards should address issues such as project management methodologies, risk management procedures, and project approval authorities.

System control standards should address items such as an application's functional, security, and automated control features. Quality assurance standards should address issues such as the validation of project assumptions, adherence to project standards, and testing of a product's performance.

¹ Deliverables are project goals and expectations. They include broadly-defined, project or phase requirements and specifically-defined tasks within project phases.

² RFP is a document that a BSFI sends to a vendor inviting the vendor to submit a bid for hardware, software, services, or any combination of the three. An institution typically issues the RFP in order to assess competing bids.

- 5.2 Development standards should also include procedures for managing internally developed spreadsheets and database reports. BSFIs often rely on the spreadsheets and reports to make important budgeting and asset/liability decisions, but fail to implement adequate testing, documentation, and change-control procedures. Management's reliance on the spreadsheets and reports should dictate the formality of their development procedures, change controls, and backup techniques.
- 5.3 Programming standards should be designed to address issues such as the selection of programming languages and tools, the layout or format of scripted code, interoperability between systems, and the naming conventions of code routines and program libraries. These will enhance the BSFI's ability to decrease coding defects and increase the security, reliability, and maintainability of application programs.

6. SYSTEM ACQUISITION

- 6.1. Software package acquisition is an alternative to in-house systems development and should be subject to broadly similar controls as the project life cycle. A proper software selection analysis should be conducted to ensure that user and business requirements are met. In particular, the process should involve detailed evaluation of the software package and its supplier (e.g., its financial condition, reputation and technical capabilities). If financial stability is in doubt, alternatives should be developed to reduce the adverse impact from loss of a vendor's service.
- 6.2. The contract agreement between the BSFI and vendor should be legally binding. The BSFI should ensure all contract agreements outline all expected service levels and are properly executed to protect its interest. It is also important to ensure that vendor technicians and third-party consultants are subjected to at least, or preferably more stringent policies and controls compared to the in-house staff. In the case where contract personnel are employed, written contracts should also be in effect.

7. CHANGE MANAGEMENT

- 7.1. Change management is the process of planning, scheduling, applying, distributing and tracking changes to application systems, system software (e.g., operating systems and utilities), hardware, network systems, and other IT facilities and equipment. The change management procedures should be formalized, enforced and adequately documented. Authorization and approval are required for all changes and the personnel responsible for program migration should be identified. For the purpose of accountability, proper sign-off should be adequately implemented where formal acknowledgement is obtained from all related parties.
- 7.2. An effective change management process helps to ensure the integrity and reliability of the production environment. To ensure IT-related modifications are appropriately authorized, tested, documented, implemented and disseminated, the change manage process should include the following:
- a. Classification and prioritization of changes and determination of the impact of changes;
 - b. Roles and responsibilities of each relevant party, including IT functions and end-user departments, with adequate segregation of duties. This is to ensure that no single person can effect changes to the production environment without the review and approval of other authorized personnel;
 - c. Program version controls and audit trails;
 - d. Scheduling, tracking, monitoring and implementation of changes to minimize business disruption;
 - e. Process for rolling-back changes to re-instate the original programs, system configuration or data in the event of production release problems; and
 - f. Post implementation verification of the changes made (e.g., by checking the versions of major amendments).
- 7.3. Requested changes should be screened before acceptance to determine alternate methods of making the changes, the cost of changes and time requirements for programming activity. System analysts should assess the impact and validity of the proposed changes and all critical change requests should be set as priority.
- 7.4. The actual cause that led to the request for change should be identified and adequately documented. Formal reports on analysis for problems raised and status of change requests (including closed and outstanding) should be reported to senior management on a periodic basis.
- 7.5. Audit trail of all change requests should be maintained. Programmers' activities should be controlled and monitored, and all jobs assigned should also be closely monitored against target completion dates.

- 7.6. To enable unforeseen problems to be addressed in a timely and controlled manner, the BSFI should establish formal procedures to manage emergency changes. Emergency changes should be approved by the information owner (for application system or production data-related changes) and other relevant parties at the time of change. If the change needs to be introduced as a matter of urgency and it is impracticable to seek the approval of the information owner, endorsement should be sought from the information owner after the implementation as soon as practicable (e.g., on the following business day).
- 7.7. Emergency changes should be logged and backed up (including the previous and changed program versions and data) so that recovery of previous program versions and data files is possible, if necessary. Emergency changes need to be reviewed by independent personnel to ensure that the changes are proper and do not have an undesirable impact on the production environment. They should be subsequently replaced by proper fixes through the normal acceptance testing and change management procedures.
- 7.8. Management should ensure that vendors permitted remote access to network resources are properly authorized. System logs showing activity on the system should be reviewed to ensure that unauthorized remote access has not taken place. Management may institute time of day restrictions for remote access, to limit the duration of time a user can access the network remotely (e.g., only during business hours). Vendors utilizing dial in access should be verified through call back procedures and/or through the use of a modem that can be turned on when authorization has been granted by the system administrator.
- 7.9. Data patching could severely compromise the integrity of the database in production systems and should strictly be avoided. The BSFI should adequately ensure the accuracy and reliability of its database and the integrity of its data. Good project management discipline requires validation of data input, data integrity testing, user sign-off, impact analysis and escalation of decision to senior management should be adopted to ensure accuracy and validity of data before live implementation.

8. SYSTEMS TESTING

- 8.1. A formal acceptance process should be established to ensure that only properly tested and approved systems are promoted to the production environment. System and user acceptance testing should be carried out in an environment separate from the production environment. Production data should not be used in development or acceptance testing unless the data has been desensitized (i.e., not disclosing personal or sensitive information) and prior approval from the information owner has been obtained. Performance testing should also be performed before newly developed systems are migrated to the production environment.
- 8.2. Sufficient testing is important to ensure that design and overall reliability of the application systems are in accordance with original specifications. Tests should be conducted using documented test plans that should encompass all predetermined data or processing problems and business scenarios.
- 8.3. User acceptance testing should be performed in a separate environment. All related users are responsible to ensure that adequate test scenarios are formulated and sufficiently tested. Successful test activities should be formally confirmed and accepted by users, before the modified programs can be transferred to the production environment.

9. SYSTEMS MIGRATION

- 9.1. A secured library for program pending migration to the production environment should be established. The secured library or quarantine area for all amended programs should only be accessible by the personnel who performed the migration process and restricted from the application programmers. This is to mitigate the risk of programmers changing the modified programs after user acceptance testing, but prior to the program migration.
- 9.2. Source compare procedure should be in place to verify changes and to ensure no unauthorized changes have been made. Modified programs should be compared to the authorized change documents to determine that only approved specification changes were implemented.
- 9.3. Updates or a version control for all applications should be maintained. Old versions of source codes¹ should be archived as contingency measure, with a clear indication of the precise date, time and all necessary information while the latest version of the source codes and databases should be strictly protected. Version controls may also be implemented to ensure only authorized programs are migrated to quarantine and production environments.

¹ Source codes are software program instructions written in format (language) readable by humans.

10. SOURCE CODE CONVERSION AND MAINTENANCE

- 10.1. Conversion of source codes into object codes¹ should be adequately controlled in order to mitigate the risks of unauthorized changes and to ensure accurate and complete results. The conversion process should only be performed by designated personnel. In the case where the compiler programs or other systems development tools are used, it should be placed under restricted control and the access and execution rights are strictly monitored.
- 10.2. In cases where core applications are developed by vendors but the source codes were not released to the BSFI, the institution's interest should be protected in the form of a written agreement. The agreement, generally known as escrow agreement, should allow the BSFI to access the source programs under conditions, such as, but not limited to, discontinued product support or financial insolvency by the vendor. A third-party entity should be appointed to retain these programs and documents in escrow. However, it is important for the BSFI to periodically determine that the source code maintained in escrow is up-to-date. If the BSFI decides not to go into a source code escrow agreement, appropriate controls or contingency plans should be established as necessary, to continue adequate operation of the business or process the acquired program is supporting in case it becomes problematic, obsolete, or ceases to function.

11. SYSTEMS DOCUMENTATION

- 11.1. All standards and procedures on systems development and documentation on user manuals should be formally established and properly maintained to ensure consistency of approach. Accessibility to these documents should be strictly confined only to those who are authorized to receive such information in order for them to effectively discharge their duties.
- 11.2. Management should identify the type and level of documentation personnel must produce during each project phase. Project documentation of major IT projects, especially development and acquisition, should include project requests, feasibility studies, project plans, testing plans, etc. System documentation, which focuses on
- 11.3. Documentation standards should identify primary documentation custodians and detail document authoring, approving, and formatting requirements. Personnel should document all changes to system, application, and configuration documentation according to prescribed standards. Additionally, management should control access to documentation libraries with appropriate library and version controls.
- 11.4. All standards and documentation should be kept secured to prevent unauthorized access. The BSFI should maintain a central storage (of either hardcopy or softcopy) of all standards and documentation onsite as well as in an offsite premise for contingency purposes. In the case where the application is developed by a vendor, management should ensure that adequate training and manuals are provided as part of the package, stated in writing and clearly understood by all parties. The BSFI should also ensure complete and updated system documentation is provided.

12. POST-IMPLEMENTATION REVIEW

- 12.1. A post implementation review should be conducted at the end of a project to validate the application's operational performance, after it has begun to operate. The relative success of the project should be gauged by comparing planned and actual cost, benefits and completion time. If the planned objectives do not materialize, reasons should be reviewed and documented in a post implementation evaluation report that should be presented to senior management highlighting any operational or project management deficiencies noted.
- 12.2. The responsibilities for conducting post-implementation review can be assigned to the BSFI's IT audit function. In larger IT organizations, formal quality assurance or change management groups may have primary responsibility for post-implementation reviews. In such cases, the IT auditor may choose not to perform a separate review but instead to participate in establishing the test criteria and evaluating results of any other independent reviews.

13. DISPOSAL

- 13.1. The BSFI may sometimes need to remove surplus or obsolete hardware, software, or data. Primary tasks include the transfer, archiving, or destruction of data records. Management should transfer data from production systems in a planned and controlled manner that includes appropriate backup and testing procedures. The BSFI should maintain archived repository of data in accordance with applicable record retention requirements and system documentation to facilitate reinstallation of a system into production, when necessary. Management should destroy data by overwriting old information or degaussing (demagnetizing) disks and tapes.

¹ Object codes are software program instructions compiled (translated) from source code into machine-readable formats.

14. ROLE OF AUDIT, INFORMATION SECURITY AND QUALITY ASSURANCE OFFICERS

- 14.1. **Audit.** The BSFI's auditors assist user departments, project managers, and system designers in identifying system control requirements and testing the controls during development and after implementation. Please refer to Item "6.1" of *Appendix Q-61* for the detailed guidelines on audit's participation in the development, acquisition, and maintenance of major systems.
- 14.2. **Information Security.** The BSFI should ensure that systems are developed, acquired and maintained with appropriate security controls. To do this, management should ensure that – a) systems are developed and implemented with necessary security features enabled and based on established security control requirements; b) software is trustworthy by implementing appropriate controls in the different project phases; and c) appropriate configuration management and change control processes exist, including an effective patch management process. Management should establish security control requirements based on their risk assessment process evaluating the value of the information at risk and the potential impact of unauthorized access, damage or other threats.
- 14.3. **Quality Assurance.** Independent quality assurance function is a critical part of well-managed IT projects. Comprehensive quality assurance, risk management, and testing standards provide the best means to manage project risks and ensure IT projects, especially software, include expected functionality, security, and operability, as applicable.

(Circular No. 958 dated 25 April 2017)

IT RISK MANAGEMENT STANDARDS AND GUIDELINES

Area: IT Operations

(Appendix to Sec. 147-Q/145-S/142-P/126-N (Purpose and Scope and IT Risk Management System))

1. INTRODUCTION

- 1.1. The evolving role IT plays in supporting the business function has become increasingly complex. IT operations – traditionally housed in a computer data center with user connections through terminals – have become more dynamic and include distributed environments, integrated applications, telecommunication options, internet connectivity, and an array of IT operating platforms¹. With the advent of technology, even small BSFIs have now become increasingly reliant on IT to achieve operational efficiency and deliver innovative products and services. Although some of these BSFIs have developed their products and services in-house, many have relied on vendors and service providers to develop and operate these products and services.
- 1.2. The increasing dependency to IT of BSFIs has consequently resulted to heightened risk exposures arising from their reliance on a variety of IT solutions and services and third-party relationships as well. It is also emphasized that risks involve more than IT and that controls include sound processes and well-trained people. To many BSFIs, effective support and delivery from IT operations has become vital to the performance of most of their critical business lines. This necessitates the adoption of risk management processes that promote sound and controlled operation of IT environments to ensure that IT operations process and store information in a timely, reliable, secure, and resilient manner.

2. ROLES AND RESPONSIBILITIES

- 2.1. **Board of Directors (Board) and Senior Management.** The BSFI's Board and senior management are responsible for overseeing a safe, sound, controlled and efficient IT operating environment that supports the institution's goals and objective. Although they can delegate implementation and oversight of daily operations to IT management, final responsibility for these activities remains with the Board and senior management. Consequently, the Board and senior management are responsible for understanding the risks associated with existing and planned IT operations, determining the risk tolerance of the BSFI, and establishing and monitoring policies for risk management.

On the other hand, IT operations management is primarily responsible in ensuring the BSFI's current and planned infrastructure is sufficient to accomplish the strategic plans of senior management and the Board. To accomplish this objective, operations management should ensure the BSFI has sufficient personnel (in knowledge, experience, and number), system capacity and availability, and storage capacity to achieve strategic objectives. Operations management should select or recommend IT solutions that can meet strategic requirements with reduced resources to control capital expenditures and operating costs.

3. IT OPERATIONS STANDARDS

- 3.1. **Technology Inventory.** To effectively identify, assess, monitor, and manage the risks associated with IT operations, management should have a comprehensive understanding of the BSFI's operations universe. Regardless of size, BSFI management should perform and maintain an inventory of all its IT resources, recognize interdependencies of these systems and understand how these systems support the associated business lines. Management should ensure the inventory is updated on an on-going basis to reflect the BSFI's IT environment at any point in time.

Appropriate documentation of infrastructure and data flow should be in place to facilitate risk identification, application of controls, and ongoing maintenance of information systems. At a minimum, said documentation should include among others, the following components:

- a. Hardware - Inventory should be comprehensive to include BSFI's owned assets and equipment owned by other parties but located within the environment. To the extent possible, hardware items should be marked with a unique identifier, such as a bar code, tamper-proof tag, or other label.

¹ IT operating platform includes the underlying computer system on which application programs run. A platform consists of an operating system, the computer system's coordinating program, which in turn is built on the instruction set for a processor or microprocessor, and the hardware that performs logic operations and manages data movement in the computer.

- b. Software - There are at least three (3) major categories of software the BSFI should include in the software inventory: operating systems, application software, and back-office and environmental applications.
- c. Network Components and Topology¹- Network management should develop and maintain high-level topologies that depict local area networks (LANs²), metropolitan area networks (MANs³) and wide area networks (WANs⁴). The topologies should have sufficient detail to facilitate network maintenance and troubleshooting, facilitate recovery in the event of a disruption and plan for expansion, reconfiguration, or addition of new technology.
- d. Data Flow Diagram - Management should also develop data flow diagrams to supplement its understanding of information flow within and between network segments as well as across the BSFI's perimeter to external parties. Data flow diagrams are also useful for identifying the volume and type of data stored on various media. In addition, the diagrams should identify and differentiate between data in electronic format, and in other media, such as hard copy or optical images.
- e. Media - Descriptive information should identify the type, capacity, and location of the media. It should also identify the location, type, and classification (public, private, confidential, or other) of data stored on the media. Additionally, management should document source systems, data ownership, back up frequency and methodology (tape, remote disk, compact disc (CD), or other), and the location of back-up media if other than at the primary off-site storage facility.

3.2. **Risk Assessment.** Once inventory is complete, management should employ a variety of risk assessment techniques to identify threats and vulnerabilities to its IT operations, covering among others, the following:

- a. Internal and external risks;
- b. Risks associated with individual platforms, systems, or processes as well as those of a systemic nature; and
- c. The quality and quantity of controls. The risk assessment process should be appropriate to the BSFI's IT risk profile. To the extent possible, the assessment process should quantify the probability of a threat or vulnerability and the financial consequences of such an event.

After the BSFI identifies and analyzes the universe of risks, management should prioritize risk mitigation actions based on the probability of occurrence and the financial, reputational or legal impact to the institution. Management should prioritize the risk assessment results based on the business importance of the associated systems. The probability of occurrence and magnitude of impact provide the foundation for establishing or expanding controls for safe, sound, and efficient operations appropriate to the risk tolerance of the BSFI.

3.3. Risk Mitigation & Control Implementation

3.3.1 Policies, Standards and Procedures. Board and management should enact policies, standards and procedures sufficient to address and mitigate the risk exposure of the BSFI. The BSFI should adopt minimum IT standards to establish measurable controls and requirements to achieve policy objectives. Procedures describe the processes used to meet the requirements of the BSFI's IT policies and standards. Management should develop written procedures for critical operations which procedures should be updated and reviewed regularly. The scope of required procedures depends on the size, complexity and the variety of functions performed by the BSFI's IT operations.

¹ A network is a group of two or more computers that are linked together. For example, networks allow users at different branches or different workstations to access the Internet, send and receive email, and share printers, applications, and data. A network topology pictorially describes the arrangement or architecture of a network, including its workstations and connecting communication lines.

² A LAN is a network that connects workstations in a relatively small geographic area, such as a building. Computers connected in a LAN are usually connected by cables, but they can also be connected wirelessly.

³ A MAN is a network that usually spans a city or a large campus. A MAN usually interconnects a number of LANs using a high-capacity backbone technology, such as fiber-optical links, and provides up-link services to WAN and the internet.

⁴ A WAN is a network that connects other networks together. WANs are typically complicated networks covering broad areas (i.e., any network that links across metropolitan, regional, or national boundaries) and allowing many computers and other devices to communicate and share data.

3.3.2 Controls Implementation

3.3.2.1 Environmental Controls. IT equipment should have a continuous uninterruptible power supply (UPS¹). Management should configure the UPS to provide sufficient electricity within milliseconds to power equipment until there is an orderly shutdown or transition to the back-up generator. The back-up generator should generate sufficient power to meet the requirements of mission critical IT and environmental support systems. Similarly, IT operations centers should have independent telecommunication feeds from different vendors. Wiring configurations should support rapid switching from one provider to another without burdensome rerouting or rewiring.

Even small IT operations centers with modest IT equipment can contain a significant amount of computer cabling. Management should physically secure these cables to avoid accidental or malicious disconnection or severing. In addition, management should document wiring strategies and organize cables with labels or color codes to facilitate easy troubleshooting, repair, and upgrade.

Every operations center should have adequate heating, ventilation, and air conditioning (HVAC) systems in order for personnel and equipment to function properly. Organizations should plan their HVAC systems with the requirements of their IT systems in mind. Also, operations personnel should be familiar with written emergency procedures in the event of HVAC system disruption.

Water leaks can cause serious damage to computer equipment and cabling under raised floors. For this reason, operations centers should be equipped with water detectors under raised flooring to alert management of leaks that may not be readily visible. Management should also consider installing floor drains to prevent water from collecting beneath raised floors or under valuable computer equipment.

A variety of strategies are available for fire suppression. Ideally, the fire suppression system should allow operators time to shut down computer equipment and cover it with waterproof covers before releasing the suppressant.

Lastly, Management should consider using video surveillance and recording equipment in all or parts of the facility to monitor activity and deter theft. Management should also use inventory labels, bar codes, and logging procedures to control the inventory of critical and valuable equipment.

3.3.2.2 Preventive Maintenance. All maintenance activities should follow a predetermined schedule. A record of all maintenance activities should be maintained to aid management in reviewing and monitoring employee and vendor performance. Management should schedule time and resources for preventive maintenance and coordinate such schedule with production. During scheduled maintenance, the computer operators should dismount all program and data files and work packs, leaving only the minimum software required for the specific maintenance task on the system. If this is impractical, management should review system activity logs to monitor access to programs or data during maintenance. Also, at least one computer operator should be present at all times when the service representative is in the computer room.

In case a vendor performs computer maintenance online, operators should be aware of the online maintenance schedule so that it does not interfere with normal operations and processing. Operators and information security personnel should adhere to established security procedures to ensure they grant remote access only to authorized maintenance personnel at predetermined times to perform specific tasks.

Operators should maintain a written log of all hardware problems and downtime encountered between maintenance sessions. A periodic report on the nature and frequency of those problems is a necessary

¹ UPS is a device that allows computer to keep running for at least a short time when the primary power source is lost. A UPS may also provide protection from power surges. A UPS contains a battery that "kicks in" when the device senses a loss of power from the primary source allowing the user time to save any data they are working on and to exit before the secondary power source (the battery) runs out. When power surges occur, a UPS intercepts the surge so that it doesn't damage the computer.

management tool, and can be valuable for vendor selection, equipment benchmarking, replacement decisions, or planning increased equipment capacity.

- 3.3.2.3 **Change Management¹ & Control.** Complex BSFIs should have a change management policy that defines what constitutes a “change” and establishes minimum standards governing the change process. Simple BSFIs may successfully operate with less formality, but should still have written change management policies and procedures.

All changes should flow through the oversight function, which may include appropriate representation from business lines, support areas, IT management, information security, and internal audit. In establishing a framework for managing change, a policy should be present describing minimum standards and including such factors as notification, oversight, and control. Control standards should address risk, testing, authorization and approval, timing of implementation, post installation validation, and back-out or recovery.

- 3.3.2.4 **Patch Management².** Management should establish procedures to stay abreast of patches, to test them in a segregated environment, and to install them when appropriate. Change management procedures should require documentation of any patch installations. Management should develop a process for managing version control of operating and application software to ensure implementation of the latest releases. Management should also maintain a record of the versions in place and should regularly monitor the Internet and other resources for bulletins about product enhancements, security issues, patches or upgrades, or other problems with the current versions of the software.

- 3.3.2.5 **Conversions.** Conversions involve major changes to existing systems or applications, or the introduction of systems or data sets which may span multiple platforms. Consequently, they have a higher level of risk requiring additional, specialized controls. Conversions, if improperly handled, may result to corrupt data; hence, strong conversion policies, procedures, and controls are critical. Likewise, since the ramifications of conversion span IT operations, it is important for management to periodically re-evaluate all operations processes and consider the appropriateness of process re-engineering.

- 3.3.2.6 **Network Management Controls.** Network standards, design, diagrams and operating procedures should be formally documented, kept updated, communicated to all relevant network staff and reviewed periodically. Communications facilities that are critical to continuity of network services should be identified. Single points of failure should be minimized by automatic re-routing of communications through alternate routes should critical nodes or links fail.

The network should be monitored on a continuous basis to reduce the likelihood of network traffic overload and detect network intrusions. Powerful network analysis and monitoring tools, such as protocol analyzers, network scanning and sniffer tools, are normally used for monitoring network performance and detecting potential or actual intrusions. These powerful network tools should be protected from unauthorized usage (e.g., viewing of unencrypted sensitive information). The use of network tools should also be tightly restricted to authorized staff only and be subject to stringent approval and review procedures.

- 3.3.2.7 **Disposal of Media.** Management should have procedures for the destruction and disposal of media containing sensitive information. These procedures should be risk-based relative to the sensitivity of the information and the type of media used to store the information. Furthermore, disposal procedures should recognize that records stored on electronic media, including tapes, and disk drives present unique

¹ Change management refers to the broad processes for managing organizational change. Change management encompasses planning, oversight or governance, project management, testing and implementation.

² A patch is a piece of software designed to fix problems with, or update a computer program or its supporting data. This includes fixing security vulnerabilities and other bugs, and improving the usability or performance. Though meant to fix problems, poorly designed patches can sometimes introduce new problems. In some special cases, updates may knowingly break the functionality, for instance, by removing components for that the update provider is no longer licensed. Patch Management is the process of using a strategy and plan of what patches should be applied to which systems at a specified time.

disposal problems in that residual data can remain on the media after erasure. Since data can be recovered, additional disposal techniques should be applied to remove sensitive information.

3.3.2.8 Imaging. Management should ensure there are adequate controls to protect imaging processes, as many of the traditional audit and controls for paper-based systems may be reduced. Management should also consider issues such as converting existing paper storage files, integration of the imaging system into the organization workflow, and business continuity planning needs to achieve and maintain business objectives.

3.3.2.9 Event/Problem Management. Management should ensure appropriate controls are in place to identify, log, track, analyze, and resolve problems that occur during day-to-day IT operations. The event/ problem management process should be communicated and readily available to all IT operations personnel. Management should ensure it trains all operations personnel to act appropriately during significant events. Employees should also receive training to understand event response escalation procedures.

Operations personnel should be properly trained to recognize events that could trigger implementation of the business continuity plan. Although an event may not initially invoke the plan, it may become necessary as conditions and circumstances change. Management should train and test BSFI personnel to implement and perform appropriate business continuity procedures within the timeframes of the BCP. Operations personnel should properly log and record any events that trigger BCP response and document their ultimate resolutions.

3.3.2.10 User Support/Help Desk. User support processes and activities should ensure end users continuously have the resources and services needed to perform their job functions in an efficient and effective manner. In complex BSFI, the help desk function provides user support, which typically consists of dedicated staff trained in problem resolution, equipped with issue tracking software, and supported with knowledge-based systems that serve as a reference resource to common problems. In simple BSFI, user support may consist of a single person, a very small group, or a contract with a support vendor.

The help desk should record and track incoming problem reports, whether handled by live operators or automated systems.

Documentation in the tracking system should include such data as user, problem description, affected system (platform, application, or other), prioritization code, current status toward resolution, party responsible for resolution, root cause (when identified), target resolution time, and a comment field for recording user contacts and other pertinent information.

The help desk should evaluate and prioritize issues to ensure the most critical problems receive prompt attention.

Help desk functions may also be supported by knowledge based-systems that provide support staff with action responses to common problems. Strong support functions continually update the knowledge based-systems with information obtained from vendors and from the experiences of help desk staff. Because attrition rates in the help desk function can be high, a knowledge based-system can ensure the BSFI retains knowledge and facilitates the training and development of new employees.

Proper authentication of users is critical to risk management within the user support function. If the help desk uses a single authentication standard for all requests, it should be sufficiently rigorous to cover the highest risk scenarios. However, the BSFI may choose to use different levels of authentication depending upon the problem reported, the type of action requested, or the platform, system, or data involved. If the help desk function is outsourced, management should determine the service provider's information access level, assign the functions it will perform, and ensure that security and confidentiality remain in place.

3.3.2.11 Scheduling. The BSFI should implement policies and procedures for creating and changing job schedules and should supplement them with automated tools when cost effective. Sound scheduling practices and controls prevent degraded processing performance that can affect response time, cause delays in completing tasks, and skew capacity planning. Automated scheduling tools are necessary for large, complex systems to support effective job processing. Smaller and less complex IT systems generally have a standard job stream with little need for change.

3.3.2.12 Systems and Data Back-up. The BSFI should ensure that sufficient number of backup copies of essential business information, software and related hardcopy documentations are available for restoration or critical operations. A copy of these information, documentation and software should also be stored in an off-site premise or backup site and any changes should be done periodically and reflected in all copies.

The BSFI should back-up and store its data and program files in a secure off-site location to allow restoration of systems, applications, and associated data in the event normal processing is disrupted by a disaster or other significant event. A full system backup should be periodically conducted and should at least consist of the updated version of the operating software, production programs, system utilities and all master and transaction files. The frequency of backup should depend on its criticality, but should be performed after critical modification or updates. Management should implement a storage solution that is manageable from an administrative perspective and usable and accessible from the customer and end-user perspectives to enable them to receive current, complete and accurate data. Storage solutions should be appropriately scalable to allow for future growth.

Written standards should document back-up methodologies, delineate responsibilities of appropriate personnel, and ensure uniform performance throughout the institution. Management should maintain inventories of back-up media stored off-site and periodically perform physical inventories to ensure all required back-up materials are available. Procedures should include verifying adherence to the back-up schedule and reviewing actual back-up copies for readability. Similarly, management should periodically test back-up copies by actually using them to restore programs and data.

All backup media should be properly labeled using standard naming conventions. Management should develop a rotation scheme that addresses varying storage durations as well as transportation and storage of multiple formats of media at the off-site storage location. Transportation to the backup site should be done in controlled and secured manner with proper authorization and record. Procedures for disposal of backup media should also be in place.

3.3.2.13 Systems Reliability, Availability and Recoverability

a. System Availability

BSFIs should achieve high systems availability (or near zero system downtime) for critical systems which is associated with maintaining adequate capacity, reliable performance, fast response time, scalability and swift recovery capability. Built-in redundancies for single points of failure should be developed and contingency plans should be tested so that business and operating disruptions can be minimized.

b. Technology Recovery Plan

Business resumption very often relies on the recovery of IT resources that include applications, hardware equipment and network infrastructure as well as electronic records. The technology requirements that are needed during recovery for individual business and support functions should be specified when the recovery strategies for the functions are determined.

Appropriate personnel should be assigned with the responsibility for technology recovery. Alternate personnel needs to be identified for key technology recovery personnel in case of their unavailability to perform the recovery process.

As unavailability of systems may result to disruptive impact on its operations, the BSFI should develop an IT disaster recovery plan to ensure that critical application systems and technology services can be resumed in accordance with the business recovery requirements. In formulating an effective recovery plan, scenario analysis should be included to identify and address various types of contingency scenarios. Scenarios such as major system outages which may be caused by system faults, hardware malfunction, operating errors or security incidents as well as a total inaccessibility of the primary data center should be considered. To strengthen recovery measures relating to large scale disruptions and to achieve risk diversification, rapid operational and backup capabilities at the individual system or application cluster level should be implemented. Recovery and business resumption priorities must be defined accordingly. Specific recovery objectives including recovery time objective¹ (RTO) and recovery point objective² (RPO) should be established for systems and applications.

c. Alternate sites for technology recovery

The BSFI should make arrangements for alternate and recovery sites³ for their business functions and technology in the event the business premises, key infrastructure and systems supporting critical business functions become unavailable. A recovery site geographically separate from the primary site must be established to enable the restoration of critical systems and resumption of business operations should a disruption occur at the primary site. The required speed of recovery will depend on the criticality of resuming business operations, the type of services and whether there are alternative ways and processing means to maintain adequate continuing service levels to satisfy customers. Recovery strategies and technologies such as on-site redundancy and real-time data replication could be explored to enhance the BSFI's recovery capability.

The recovery site could either be an in-house backup premise that has a redundant hardware system located away from the computer center, or a third-party recovery facility provider that requires formal subscription to its service, or a combination of both solutions. The recovery facility should be at a distance that would protect it from damage from any incident occurring at the primary site. Ideally, it should be on different electrical power and telecommunication switches, and free from the same disaster. The BSFI should ensure that the IT systems at the recovery sites are:

- a. Compatible with the BSFI's primary systems (in terms of capacity and capability) to adequately support the critical business functions; and
- b. Continuously updated with current version of systems and application software to reflect any changes to the BSFI's system configurations (e.g., hardware or software upgrades or modifications).

In case where a third-party recovery facility is used, there should be a written contract agreement that is legally binding. The agreement should specifically identify the conditions under which the recovery facility may be used and specify how customers would be accommodated if simultaneous disaster conditions occur to several customers of the recovery facility provider. The recovery facility should allow the BSFI to use its services until it achieves a full recovery from the disaster and resumption of activity at the BSFI's own facility.

The BSFI which outsources critical systems to offshore service providers is heavily dependent on the stability and availability of cross-border network links. To minimize impact to business operations in the event of a disruption (e.g., due to earthquake), cross-border network redundancy with strategies such as engagement of different network service providers and alternate network paths may be instituted.

¹ RTO refers to the required time taken to recover an IT system from the point of disruption.

² RPO refers to the acceptable amount of data loss for an IT system should a disaster occur.

³ Recovery site is an alternate location for processing information (and possibly conducting business) in an emergency.

d. **Disaster Recovery Testing**

The BSFI should always adopt pre-determined recovery actions that have been tested and endorsed by management. The effectiveness of recovery requirements and the ability of BSFI's personnel in executing or following the necessary emergency and recovery procedures should be tested and validated at least annually.

Various scenarios which include total shutdown or inaccessibility of the primary data center, as well as component failure at the individual system or application cluster level should be included in disaster recovery tests. Inter-dependencies between and among critical systems should be included in the tests. BSFIs whose networks and systems are linked to specific service providers and vendors, should consider conducting bilateral or multilateral recovery testing.

Business users should be involved in the design and execution of comprehensive test cases so as to obtain assurance that recovered systems function accordingly. The BSFI should also participate in disaster recovery tests of systems hosted overseas. Periodic testing and validation of the recovery capability of backup media should be carried out and assessed for adequacy and effectiveness. Backup tapes and disks containing sensitive data should be encrypted before they are transported offsite for storage.

3.4. Risk Monitoring

3.4.1 **Service Level Agreement (SLA).** BSFI Management of IT functions should formulate an SLA with business units which will measure the effectiveness and efficiency of delivering IT services. Measurable performance factors include system availability and performance requirements, capacity for growth, and the level of support provided to users, resource usage, operations problems, capacity, response time, personnel activity, as well as business unit and external customer satisfaction. Adequate procedures should be in place to manage and monitor delivery of services.

3.4.2 **Control Self-Assessments¹ (CSAs).** The BSFI may consider the conduct of periodic CSAs to validate the adequacy and effectiveness of the IT control environment. They also facilitate early identification to allow management to gauge performance, as well as the criticality of systems and emerging risks. Depending on the complexity of the BSFI's IT risk profile, the content and format of the CSAs may be standardized and comprehensive or highly customized, focusing on a specific process, system, or functional area. IT operations management may collaborate with the internal audit function in creating the templates used. Typically, the CSA form combines narrative responses with a checklist. The self-assessment form should identify the system, process, or functional area reviewed, and the person(s) completing.

¹ CSA is a technique used to assess risk and control strength and weaknesses against a control framework.

IT RISK MANAGEMENT STANDARDS AND GUIDELINES

Area: IT Outsourcing / Vendor Management

(Appendix to Sec. 147-Q/145-S/142-P/126-N (Purpose and Scope and IT Risk Management System))

1. INTRODUCTION

- 1.1. With globalization and advancement in IT, BSFIs increasingly rely on services provided by other entities to support an array of IT-related functions. The ability to outsource IT systems and process enables a BSFI to manage costs, obtain necessary expertise, expand customer product offerings, and improve services. While outsourcing offers a cost-effective alternative to in-house capabilities, it does not reduce the fundamental risks associated with IT or the business lines that use it. Risks such as loss of funds, loss of competitive advantage, damaged reputation, improper disclosure of information and regulatory action remain. Because the functions are performed by an organization outside the BSFI, the risks may be realized in a different manner than if the functions were inside resulting in the need for well-structured process to properly manage risks and ensure that the interest of customers will not be compromised.

2. ROLES AND RESPONSIBILITIES

- 2.1. Board of Directors (Board) and Senior Management. The responsibility for the oversight and management of outsourcing activities and accountability for all outsourcing decisions continue to rest with the BSFI's Board and senior management. They should establish and approve enterprise-wide policies, appropriate to the IT risk profile of the institution. This framework should govern the end-to-end perspective of outsourcing process and shall provide the basis for management to identify, measure, monitor, and control the risks associated with IT-related outsourcing arrangements.

3. IT OUTSOURCING / VENDOR RISK MANAGEMENT PROGRAM

- 3.1. **Risk Assessment.** Prior to entering into an outsourcing plan, the BSFI should clearly define the business requirements for the functions or activities to be outsourced, assess the risk of outsourcing those functions or activities and establish appropriate measures to manage and control the identified risks. Risk assessment should take into consideration the criticality of the services to be outsourced, the capability of the technology service provider (TSP)¹ and the technology it will use in delivering the outsourced service. Such assessment should be made periodically on existing arrangements as part of the outsourcing program and review process of the BSFI.

- 3.2. **Service Provider Selection.** Before selecting a service provider, the BSFI should perform appropriate due diligence of the provider's financial soundness, reputation, managerial skills, technical capabilities, operational capability and capacity in relation to the services to be outsourced. The depth and formality of the due diligence performed may vary depending on the nature of the outsourcing arrangement and the BSFI's familiarity with the prospective service providers. Contract negotiation should be initiated with the service provider determined to best meet the business requirements of the BSFI.

Due diligence undertaken during the selection process should be documented and reviewed periodically, using the most recent information, as part of the monitoring and control processes of outsourcing.

- 3.3. **Outsourcing Contracts.** The contract is the legally binding document that defines all aspects of the servicing relationship and one of the most important controls in outsourcing process. It should be clearly written and sufficiently detailed to provide assurances for performance, reliability, security, confidentiality and reporting. Before signing a contract, management should:
 - a. Ensure the contract clearly defines the rights and responsibilities of both parties and contains or supported by adequate and measurable service level agreements;
 - b. Ensure contracts with related entities clearly reflect an arms-length relationship and costs and services are on terms that are substantially the same, or at least as favorable to the BSFI, as those prevailing at the time for comparable transactions with non-related third parties;

¹ TSPs include a wide range of entities including but not limited to affiliated entities, non-affiliated entities, and alliances of companies providing technology products and services. These services may include but not limited to the following: a) information and transaction processing and settlement activities that support banking functions; b) electronic banking-related services; c) Internet-related services; d) security monitoring; e) systems development and maintenance; f) aggregation services; and g) digital certification services. Other terms used to describe TSPs include vendors and external/outsourced service providers

- c. Choose the most appropriate pricing method for the BSFI's needs;
- d. Ensure service provider's physical and data security standards meet or exceed the BSFI's standards. Any breach in security should be reported by the service provider to the BSFI;
- e. Engage legal counsel to review the contract; and
- f. Ensure the contract contains the minimum provisions required under existing Bangko Sentral rules and regulations, like access by Bangko Sentral to systems and databases outsourced, and the same does not include any provisions or inducements that may adversely affect the BSFI (i.e. extended terms, significant increases after the first few years, substantial cancellation penalties).

Each agreement should allow for renegotiation and renewal to enable the BSFI to retain an appropriate level of control over the outsourcing and the right to intervene with appropriate measures to meet its legal and regulatory obligations. The agreement should also acknowledge Bangko Sentral's supervisory authority over the BSFI and the right of access to information on the BSFI and the service provider.

Some service providers may contract with third-parties in providing IT services to the BSFI. The extent to which subcontractors perform additional services should be limited to peripheral or support functions while the core services should rest with the main service provider. The BSFI should retain the ability to maintain similar control over its outsourcing risks when a service provider uses subcontractors in the course of rendering the IT-related services. Agreements should have clauses setting out the rules and limitations on subcontracting. To provide accountability, it may be beneficial for the BSFI to include a provision specifying that the contracting service provider shall remain fully responsible with respect to parts of the services which were further outsourced to subcontractors. It should also consider including notification and approval requirements regarding changes to the service provider's significant subcontractors.

An annual review of the outsourcing agreements should be performed to assess whether the agreements should be renegotiated and renewed to bring them in line with current market standards and to cope with changes in their business strategies. When renegotiating contracts, the BSFI should ensure that the provider delivers a level of service that meets the needs of the institution over the life of the contract.

- 3.4. **Service Level Agreement (SLA).** SLAs formalize the performance standards against which the quantity and quality of service should be measured. Management should include SLAs in its outsourcing contracts to specify and clarify performance expectations, as well as establish accountability for the outsourced activity.

The BSFI should link SLA to the provisions in the contract regarding incentives, penalties and contract cancellation in order to protect themselves in the event the service provider failed to meet the required level of performance.

Management should closely monitor the service provider's compliance with key SLA provision on the following aspects, among others:

- a. Availability and timeliness of services;
- b. Confidentiality and integrity of data;
- c. Change control;
- d. Security standards compliance, including vulnerability and penetration management;
- e. Business continuity compliance; and
- f. Help desk support.

SLAs addressing business continuity should measure the service provider's contractual responsibility for backup, record retention, data protection, and maintenance and testing of disaster recovery and contingency plans. Neither contracts nor SLAs should contain any extraordinary provisions that would exempt the service provider from implementing its contingency plans (outsourcing contracts should include clauses that discuss unforeseen events for which the BSFI would not be able to adequately prepare).

3.5. Ongoing Monitoring

- 3.5.1 **Monitoring Program.** As outsourcing relationships and interdependencies increase in materiality and complexity, the BSFI needs to be more proactive in managing its outsourcing relationships. It should establish a monitoring program to ensure service providers deliver the quantity and quality of services required by the contract. The resources to support this program will vary depending on the criticality and complexity of the system, process, or service being outsourced.

The program should employ effective mechanisms to monitor key aspects of the outsourcing relationship and the risk associated with the outsourced activity, particularly the following:

- a. contract/SLA performance;
- b. material problems encountered by the service provider which may impact the BSFI;
- c. financial condition and risk profile; and
- d. business continuity plan, the results of testing thereof and the scope for improving it.

To increase the effectiveness of monitoring mechanisms, management should periodically classify service provider relationships to determine which service providers require closer monitoring. Relationships with higher risk classification should receive more frequent and stringent monitoring for due diligence, performance (financial and/or operational), and independent control validation reviews.

Personnel responsible for monitoring activities should have the necessary expertise to assess the risks and should maintain adequate documentation of the process and results thereof. Management should use such documentation when renegotiating contracts as well as developing business continuity planning requirements.

Reports on the monitoring and control activities of the BSFI should be prepared or reviewed by its senior management and provided to its Board. The BSFI should also ensure that any adverse development arising from any outsourced activity is brought to the attention of the senior management, or the Board, when warranted, on a timely basis. Actions should be taken to review the outsourcing relationship for modification or termination of the agreement.

- 3.5.2 **Financial Condition of Service Providers.** The BSFI should have an on-going monitoring of the financial condition of its service providers as financial problems may jeopardize the quality of its service and possibly the integrity of the data in its possession. In the event management recognizes that the financial condition of the provider is declining or unstable, more frequent financial reviews of said provider are warranted.

- 3.5.3 **General Control Environment of the Service Provider.** The BSFI should also implement adequate measures to ensure service providers are only given access to the information and systems that they need in order to perform their function. Management should restrict their access to BSFI's systems, and appropriate access controls and monitoring should be in place between the service provider's systems and the BSFI.

- 3.6. **Business Continuity Planning Consideration.** The BSFI should integrate the provider's BCP into its own plan, communicate functions to the appropriate personnel, and maintain and periodically review the combined plan. It should ensure that service provider tests its plan annually and notify the institution of any resulting modifications.
- 3.7. **Compliance with Bangko Sentral Regulations.** The BSFI should ensure that appropriate up-to-date records relevant to its outsourcing arrangements are maintained in its premises and kept available for inspection by the Bangko Sentral Examiners. The outsourcing agreement should explicitly provide a clause allowing Bangko Sentral and BSFI's internal and external auditors to review the operations and controls of the service provider as they relate to the outsourced activity.

In addition to the general guidelines on outsourcing contracts stated in Item No. "3.3" of this Appendix, the BSFIs intending to outsource must comply with existing Bangko Sentral rules and regulations on outsourcing.

IT RISK MANAGEMENT STANDARDS AND GUIDELINES

Area: Electronic Banking, Electronic Payment, Electronic Money and Other Electronic Products and Services
(Appendix to Sec. 147-Q/145-S/142-P/126-N (Purpose and Scope and IT Risk Management System))

1. INTRODUCTION

- 1.1. Continuing technological innovation and competition among existing FIs and new entrants have contributed to a wide array of electronic products and services (e-services) available to customers. These products and services have been widely adopted by BSFIs in recent years and are now a component of most institutions' business strategy. Electronic delivery of services can have many benefits for BSFIs and their customers and can also have implications on financial condition, risk profile, and operating performance. The emergence of e-services may contribute to improving the efficiency of the banking and payment system, reducing the cost of retail transactions nationally and internationally and expanding the target customers beyond those in traditional markets. Consequently, BSFIs are therefore becoming more aggressive in adopting electronic capabilities that include sophisticated marketing systems, remote-banking capabilities, and stored value programs.
- 1.2. Notwithstanding the significant benefits of technological innovation, the rapid development of electronic capabilities carries risks as well as benefits and it is important that these risks are recognized and managed by BSFIs in a prudent manner to promote safe and secure e-services and operations. The basic types of risks generated by e-services are not new, the specific ways in which some of the risks arise, as well as the magnitude of their impact may be new for BSFIs and supervisors. While existing risk management guidelines remain applicable to e-services, such guidelines must be tailored, adapted and, in some cases, expanded to address the specific risk management challenges created by the characteristics of such activities. As the industry continues to address technical issues associated with e-services, including security challenges, a variety of innovative and cost efficient risk management solutions are likely to emerge. These solutions are also likely to address issues related to the fact that BSFIs differ in size, complexity and risk management culture and that jurisdictions differ in their legal and regulatory frameworks.

2. ROLES AND RESPONSIBILITIES

- 2.1. **Board of Directors (Board) and Senior Management.** The Board is expected to take an explicit, informed and documented strategic decision as to whether and how the BSFI is to provide e-services to their customers. The Board and senior management should establish effective management oversight of the risks associated with these activities, including the establishment of specific accountability, policies and controls to manage these risks. Senior management oversight processes should operate on a dynamic basis in order to effectively intervene and correct any material systems problems or security breaches that may occur.

The Board should ensure that plans to offer e-services are consistent and clearly integrated within corporate strategic goals. The BSFI should also ensure that it does not offer new e-services or adopt new technologies unless it has the necessary expertise to provide competent risk management oversight. Management and staff expertise should be commensurate with the technical nature and complexity of the BSFI's applications and underlying technologies.

The Board and senior management should ensure that the operational and security risk dimensions of the BSFI's business strategies on e-services are appropriately considered and addressed. The provision of e-services may significantly modify and/or even increase traditional business risks. As such management should take appropriate actions to ensure that the BSFI's existing risk management, security control, due diligence and oversight processes for outsourcing relationships are appropriately evaluated and modified to accommodate e-services.

BSFI management should assess the impact of the implementation and ongoing maintenance of e-services. These areas should be monitored and analyzed on an ongoing basis to ensure that any impact on the BSFI's financial condition and risk profile resulting from e-services is appropriately managed and controlled. Management should evaluate e-services acceptance vis-à-vis the performance to its goals and expectations through periodic review of reports tracking customer usage, problems such as complaints and downtime, unreconciled accounts or transactions initiated through the system, and system usage relative to capacity. Insurance policies may also need to be updated or expanded to cover losses due to system security breaches, system downtime, or other risks from e-services.

- 2.2. **Compliance Officer.** The compliance officer or its equivalent should be aware and informed of all relevant laws and regulatory requirements relative to the offering of e-services, including those of other countries where they also intend to deliver cross-border e-services. BSFI management should ensure that these requirements are complied with to minimize legal and compliance risks and other negative implications.

3. RISK MANAGEMENT SYSTEM

- 3.1. The BSFI should carefully evaluate the offering of a new e-service to customers to ensure that Management fully understands the risk characteristics and that there are adequate staffing, expertise, technology and financial resources to launch and maintain the service. A formal business strategy for introducing new service should be in place and form part of the BSFI's overall strategy. The BSFI should also perform regular assessments to ensure that its controls for managing identified risks remain proper and adequate.
- 3.2. The underlying risk management processes for e-services should be integrated into the BSFI's overall risk management framework and the existing risk management policies and processes should be evaluated to ensure that they are robust enough to cover the new risks posed by current or planned activities. Relevant internal controls and audit as required in BSFI's risk management system should also be enforced and carried out as appropriate for its e-services. Regular review of the relevant policies and controls should be performed to ascertain that these remain appropriate to the risks associated with such activities.
- 3.3. The BSFI should adjust or update, as appropriate, its information security program in the light of any relevant changes in technology, the sensitivity of its customer information and internal or external threats to information. The BSFI should ensure that the related information security measures and internal control are installed, regularly updated, monitored and are appropriate with the risks associated with their products and services.

4. RISK MANAGEMENT CONTROLS

- 4.1. **Security Controls.** The BSFI should recognize that e-services should be secured to achieve a high level of confidence with both customers and business. It is the responsibility of BSFI management to provide adequate assurances that transactions performed and information flowed through the electronic delivery channels are properly protected. For this reason, the BSFI should maintain a strong and comprehensive security control system. As such, in addition to the information security standards in *Appendix Q-62*, the BSFI should also provide the following controls specific for e-services:

- 4.1.1. **Account Origination and Customer Verification.** The BSFI should use reliable methods for originating new customer accounts. Potentially significant risks may arise when it accepts new customers through the internet or other electronic channels. Thus, the BSFI should ensure that in originating new accounts using electronic channels, the KYC requirement which involves a face-to-face process is strictly adhered to.

- 4.1.2. **Authentication¹.** The BSFI should use reliable and appropriate authentication methods to validate and verify the identity and authorization of customers. Authentication is facilitated by the use of factors, which are generally classified into three (3) basic groups:

- a. Knowledge – Something the user knows (e.g., username, password, mobile PIN, card number account number);
- b. Possession – Something the user has (e.g., payment card, token, one-time password); and
- c. Inherence – Something the user is (e.g., biometrics).

As the number of factors increases, the window of compromise becomes more difficult. The use of single factor authentication alone is considered inadequate to address the risks inherent in sensitive communications and/or high-risk transactions. Thus, BSFIs should adopt multi-factor authentication (MFA) or use a minimum of two (2) factors in such instances. This requirement shall apply to online transactions where the risk of compromise is heightened. Sensitive communications and/or high-risk transactions requiring MFA include, among others, the following:

- a. Enrollment in transactional e-services;
- b. Payments and transfers to third parties;
- c. Online remittance, including those for pick-up at the BSFI branches via door-to-door delivery;
- d. Account maintenance, including change in account information and contact details; and
- e. Use of payment cards (e.g., ATM, credit and debit cards) in e-commerce websites.

For transactions that do not require real-time or near real-time authentication/ authorization, BSFIs may also opt to use positive confirmation in lieu of MFA. Positive confirmation refers to any form of communication that will enable the BSFI to timely and accurately verify the identity of the requesting

¹ BSFIs shall comply with the foregoing requirements on customer authentication by 30 September 2017. In this regard, a BSFI should be able to show its plan of actions with specific timelines, as well as the status of initiatives being undertaken to fully comply with the provisions of Item "4.1.2" of this Appendix, upon request of the Bangko Sentral starting May 2017. This transitory period, however, should not excuse BSFIs from immediately complying with the MFA requirements imposed by affiliated payment networks.

customer. The BSFI should use a different communication channel other than the one where the request originated from when confirming sensitive communications and/or high-risk transactions.

The adoption of MFA techniques or positive confirmations for sensitive communications and/or high-risk transactions can increase customer confidence in e-services. In addition, it provides an opportunity for the customers to assist the BSFI in preventing and detecting fraudulent activity. Nevertheless, alternative and less stringent authentication procedures may be considered for the following:

- a. Small-value payment or other low-risk transactions, provided the same are justified by a *transaction risk analysis*¹ and bounded by prudent thresholds established by the BSFI. The BSFI's methodology for setting the threshold should be adequately documented and independently validated at least annually;
- b. Payments and transfers made to pre-enrolled merchants in the bills payment facility and those pre-registered recipients by the customer: *Provided*, That the BSFI employs a robust and reliable enrollment process for third party merchants and recipients; and
- c. Transaction between two (2) accounts of the same customer at the same BSFI.

As authentication methods continue to evolve, the BSFI should monitor, evaluate, and adopt sound industry practices to address current and changing risk factors. The authentication process should be consistent with and support the BSFI's overall security and risk management programs. An effective authentication process should have customer acceptance, reliable performance, scalability to accommodate growth and interoperability with existing systems and future plans as well as appropriate policies, procedures and controls.

(As amended by Circular No. 958 dated 25 April 2017)

4.1.3. Non-Repudiation². As customers and merchants originate an increasing number of transactions, authentication and encryption become increasingly important to ensure non-repudiation of transactions. In such cases, the BSFI should consider implementing non-repudiation controls in the form of digital signatures, collision-free hash value of the entire transaction or unique authorization code that will provide conclusive proof of participation of both the sender and receiver in an online transaction environment. Public key infrastructure³, digital signature⁴, digital certificate⁵ and certification authority⁶ arrangements can be used to impart an enhanced level of security authentication and authorization which can uniquely identify the person initiating transaction, detect unauthorized modifications and prevent subsequent disavowal.

4.1.4. Authorization Controls and Access Privileges. Specific authorization and access privileges should be assigned to all individuals, agents or systems, which conduct activities on e-services. No individual agent or system should have the authority to change his or her own authority or access privileges in the e-services authorization database. Any addition of an individual, agent or system or changes to access privileges should be duly authorized by an authenticated source empowered with adequate authority and subject to suitable and timely oversight and audit trails.

All systems that support e-services should be designed to ensure that they interact with a valid authorization database. Appropriate measures should be in place in order to make authorization databases reasonably resistant to tampering. Authenticated e-services sessions should remain secure throughout the full duration of the session. In the event of a security lapse, the session should require re-authentication. Controls should also be in place to prevent changes to authorization levels during e-services sessions and any attempts to alter authorization should be logged and brought to the attention of management.

No person by virtue of rank or position should have any intrinsic right to access confidential data, applications, system resources or facilities. Only employees with proper authorization and whose official duties necessitate access to such data, applications, system resources or facilities should be allowed to access confidential information and use system resources solely for legitimate purposes.

¹ Transaction risk analysis refers to the evaluation of risk related to a specific transaction taking into account various criteria including, but not limited to, customer behavioral transaction pattern, payee profile, nature of product/service to be acquired and transaction value.

² Non-repudiation is a means of ensuring that a transferred message has been sent and received by the parties claiming to have sent and received the message. Non-repudiation is a way to guarantee that the sender of a message cannot later deny having sent the message and that the recipient cannot deny having received the message.

³ Public Key Infrastructure (PKI) refers to the use of public key cryptography in which each customer has a key pair (i.e., unique electronic value called a public key and a mathematically-related private key). The private key is used to encrypt (sign) a message that can only be decrypted by the corresponding public key or to decrypt message previously encrypted with the public key. The public key is used to decrypt message previously encrypted (signed) using an individual's private key or to encrypt a message so that it can only be decrypted (read) using the intended recipient's private key.

⁴ Digital certificate is a digital code that can be attached to an electronically transmitted message that uniquely identifies the sender. Like a written signature, the purpose of a digital signature is to guarantee that the individual sending the message really is who he or she claims to be.

⁵ Digital Certificate is the electronic equivalent of an ID card that authenticates the originator of digital signature.

⁶ Certification Authority (CA) is the organization that attests using a digital certificate that a particular electronic message comes from a specific individual or system.

4.1.5. **Confidentiality and Integrity of Information, Transactions and Records.** The BSFI should ensure that appropriate measures are in place to ascertain the accuracy, completeness and reliability of e-services transactions, records and information that are either transmitted over the internal and external networks or stored in BSFI's internal systems. Common practices used to maintain data integrity include the following:

- a. E-services transactions should be conducted in a manner that make them highly resistant to tampering throughout the entire process;
- b. E-services records should be stored, accessed and modified in a manner that make them highly resistant to tampering;
- c. E-services transaction and record-keeping processes should be designed in a manner as to make it virtually impossible to circumvent detection of unauthorized changes;
- d. Adequate change control policies,
- e. including monitoring and testing procedures, should be in place to protect against any system changes that may erroneously or unintentionally compromise controls or data reliability; and
- f. Any tampering with e-services transactions or records should be detected by transaction processing, monitoring and record keeping functions.

The BSFI should implement appropriate technologies to maintain confidentiality and integrity of sensitive information, in particular customer information. Cryptographic technologies can be used to protect the confidentiality and integrity of information and the extent of protection needed and, only those that are making use of internationally recognized cryptographic algorithms where the strengths of the algorithms have been subjected to extensive tests. In cases when the information is transmitted over public network, the BSFI should consider the need to apply strong end-to-end encryption to the transmission of sensitive information.

To ensure adequate protection and secrecy of cryptographic keys whether they are master keys, key encrypting keys or data encrypting keys, no single individual should know entirely what the keys are or have access to all the constituents making up these keys. All keys should be created, stored, distributed or changed under the most stringent conditions. Likewise, use of these keys should be logged and provided with timely oversight.

4.1.6. **Application Security.** The BSFI should ensure an appropriate level of application security in its electronic delivery systems. In selecting system development tools or programming languages for developing e-services application systems, it should evaluate the security features that can be provided by different tools or languages to ensure that effective application security can be implemented. In selecting an e-services system developed by a third party, the BSFI should take into account the appropriateness of the application security of the system. It should test new or enhanced applications thoroughly using a general accepted test methodology in a test environment prior to implementation.

Comprehensive and effective validation of input parameters (including user-supplied data and database queries that may be submitted by the users' computers) should be performed on server side. This prevents intentional invalid input parameters from being processed by the e-services system that may result in unauthorized access to data, execution of commands embedded in the parameters or a buffer overflow attack¹. Moreover, e-services systems should operate with the least possible system privileges.

Error messages generated by the application system for e-services customers should not reveal details of the system which are sensitive. Errors should be appropriately logged. Similarly, the HTML² source code on the production web server should not contain sensitive information such as any references or comments that relate to the design features of the web application code.

The mechanism for managing an active e-services session should be secure. Web pages containing sensitive information should not be cached in the temporary files of browsers. The application should ideally prohibit the customers' browsers from memorizing or displaying the user IDs and passwords previously entered by customers and the web pages previously accessed by customers.

When a known vulnerability related to the e-services application system is identified or reported, a review of the relevant program source code should be conducted as appropriate to ensure that the vulnerability is appropriately addressed. A security standard may be defined for the purpose of system development and code review. For third-party developed systems, the patches provided by vendors from time to time should be appropriately applied to these systems.

¹ Buffer overflow attack is a method of overloading a predefined amount of space in a buffer, which can potentially overwrite and corrupt memory in data.

² Hypertext Markup Language (HTML) is a set of codes that can be inserted into text files to indicate special interfaces, inserted images, and links to the hypertext documents.

Hidden directories that contain administrative pages or sensitive information of the web site should either be removed from the production web server or protected by effective authentication and access control mechanisms. Back-up files and common files should be removed from the production servers or the structure of file directories to prevent access by unauthorized users. A periodic security review of the structure of file directories and access controls of the files is necessary to ensure that all sensitive files are appropriately protected and not exposed through the web applications.

- 4.1.7. **Infrastructure and Security Monitoring.** The BSFI should establish an appropriate operating environment that supports and protects systems on e-services. It should proactively monitor systems and infrastructure on an ongoing basis to detect and record any security breaches, suspected intrusions, or weaknesses. The BSFI should ensure that adequate controls are in place to detect and protect against unauthorized access to all critical e-services systems, servers, databases, and applications. The attached *Annex "A"* provides for the minimum security measures for e-services facilities.

The BSFI should put in place effective monitoring mechanisms to detect in a timely manner suspicious online transactions and unusual activities. A sound monitoring system should include audit features that can assist in the detection of fraud, money laundering, compromised passwords or other unauthorized activities. In particular, the monitoring mechanism for personal e-services should be able to detect cases similar to the following:

- a. False or erroneous application information, large check deposits on new e-services accounts, unusual volume or size of funds transfers, multiple new accounts with similar account information or originating from the same internet address, and unusual account activity initiated from a foreign internet address;
- b. Multiple online transfers are made to the same unregistered third-party account within a short period of time especially if the amount transferred is close to the maximum amount allowed or the value exceeds a certain amount; and
- c. Change of a customer's correspondence address shortly followed by transactions which may indicate potential fraudulent activities such as opening of an e-service account online, a request for important documents (e.g., cheque book, new e-banking password, credit card/ATM PIN) to be mailed to that address, increase of fund transfer limits, or a sudden increase of fund transfers made to unregistered third parties.

The BSI's monitoring staff should be promptly alerted by its monitoring mechanism if suspicious online transfers and unusual activities are initiated. In these cases, the BSI should, as soon as practicable, check with the account holders of these transactions or activities. Consideration should also be given to notifying personal customers immediately through an alternative automated channel (such as messages sent to mobile phones or e-mail accounts of customers) of online transfers made to unregistered third parties, online transfers exceeding certain amount limits, or detected unusual activities related to their accounts.

- 4.1.8. **Audit Trail.** The BSFI should ensure that comprehensive logs are maintained to record all critical e-services transactions to help establish a clear audit trail and promote employee and user accountability. Audit logs should be protected against unauthorized manipulation and retained for a reasonable period [e.g., three (3) months] to facilitate any fraud investigation and any dispute resolution if necessary. In instances where processing systems and related audit trails are the responsibility of a third-party service provider, the BSFI should ensure that it has access to relevant audit trails maintained by the service provider in accordance with existing standards. In particular, clear audit trails should exist under the following types of e-services transactions:

- a. the opening, modification or closing of a customer's account;
- b. any transaction with financial consequences;
- c. any authorization granted to a customer to exceed a limit; and
- d. any granting, modification or revocation of systems access right or privileges.

- 4.1.9. **Segregation of Duties.** As in any traditional process, segregation of duties is a basic internal control measure designed to reduce the risk of fraud in operational processes and systems. The BSFI management should ensure that duties are adequately separated and transaction processes are designed in a manner that no single person could initiate, approve, execute and enter transactions into a system that would enable fraudulent actions to be perpetrated and concealed. Segregation should also be maintained between (a) those developing and those administering the systems; and (b) those initiating static data (including web

page content) and those responsible for verifying its integrity. E-services systems should be tested to ensure that segregation of duties cannot be bypassed.

- 4.1.10. **Website Information and Maintenance.** Because the BSFI's website is available on an ongoing basis to the general public, appropriate procedures should be established to ensure accuracy and appropriateness of its information. Key information changes and updates (such as deposit, loan and foreign exchange rates), are normally subject to documented authorization and dual verification. Procedures and controls to monitor and verify website information frequently may help prevent any inadvertent or unauthorized modifications or content that could lead to reputational damage or violations of advertising, disclosure, or other compliance requirements.

In addition, some BSFIs provide various tools and other interactive programs to enable customers to submit online application or provide resources for them to research available options associated with BSFI's products and services on-line. To protect the BSFI from potential liability or reputational harm, it should test or otherwise verify the accuracy and appropriateness of these tools and programs.

The BSFI should carefully consider how links to third-party Internet Web sites are presented. "Hyperlinks¹" may imply an endorsement of third-party products, services, or information that could lead to implicit liability for the BSFI. The BSFI should provide disclaimers when such links take the customer to a third-party web site to ensure that they clearly understand any potential liabilities arising out of any such cross-marketing arrangements or other agreements with third parties. Any links to sites offering non-deposit, investment or insurance products must comply with existing regulations. Links to other sites should be verified regularly for accuracy, functionality, and appropriateness.

The BSFI should manage the risk associated with fraudulent emails or websites which are designed to trick its customers into revealing private details such as account numbers or e-services passwords. To this end, the BSFI should consider educating customers the ways to ensure that they are communicating with the official website and that they will not be required to access the BSFI's transactional e-services portal through hyperlinks embedded in e-mails unless the website is validated by legitimate digital certificate.

Additionally, the BSFI should exercise care in selecting its website name(s) in order to reduce possible confusion with those of other Internet sites. It should periodically scan the Internet to identify sites with similar names and investigate any that appear to be posing as the institution. Suspicious sites should be reported to appropriate law enforcement agencies and regulatory authorities.

4.2. Administrative and Management Controls

- 4.2.1. **Service Availability and Business Continuity.** The BSFI should have the ability to deliver e-services to all end-users and be able to maintain such availability in all circumstances within a reasonable system response time in accordance with its terms and conditions and anticipated customer expectations. Performance criteria for each critical e-service should be established and service levels should be monitored against these criteria. Appropriate measures should be taken to ensure that e-services systems and the interfaces with the internal systems can handle the projected transaction volume and future growth in transactions.

Appropriate business continuity and contingency plans for critical e-services processing and delivery systems should be in place and regularly tested. Contingency plans should set out a process for restoring or replacing e-services processing capabilities, reconstructing supporting transaction information, and include measures to be taken to resume availability of critical e-services systems and applications in the event of a business disruption.

- 4.2.2. **Incident Response and Management.** The BSFI should put in place formal incident response and management procedures for timely reporting and handling of suspected or actual security breaches, fraud, or service interruptions of their e-services during or outside office hours. A communication strategy should be developed to adequately address the reported concerns and an incident response team should be established to manage and respond to the incident in accordance with existing standards enumerated in *Appendix Q-62*.

- 4.2.3. **Outsourcing Management.** Increased reliance upon partners and third party service providers to perform critical e-services functions lessens BSFI management's direct control. Accordingly, a comprehensive process for managing the risks associated with outsourcing and other third-party dependencies is necessary to ensure that:

¹ Hyperlink is an item on a webpage, that, when selected, transfers the user directly to another location in a hypertext document or to another webpage, perhaps on a different machine

- a. The BSFI fully understands the risks associated with entering into an outsourcing or partnership arrangement for its e-services systems or applications;
- b. An appropriate due diligence review of the competency and financial viability of any third-party service provider or partner is conducted prior to entering into any contract for e-services;
- c. The contractual accountability of all parties to the outsourcing or partnership relationship is clearly defined. For instance, responsibilities for providing information to and receiving information from the service provider should be clearly defined;
- d. All outsourced e-services systems and operations are subject to risk management, security and privacy policies that meet the BSFI's own standards;
- e. Periodic independent internal and/or external audits are conducted of outsourced operations to at least the same scope required if such operations were conducted in-house; and
- f. Appropriate contingency plans for outsourced e-services activities exist.
- g. Complete guidelines for managing outsourcing relationships and third party dependencies are enumerated in *Appendix Q-65*.

4.3. Consumer Protection

- 4.3.1. Customer Privacy and Confidentiality. The BSFI should take appropriate measures to ensure adherence to customer privacy requirements applicable to the jurisdictions to which the institution is providing electronic products and services. Misuse or unauthorized disclosure of confidential customer data exposes the entity to both legal and reputation risk. To meet these challenges concerning the preservation of privacy of customer information, the BSFI should make reasonable endeavors to ensure that:
 - a. The BSFI's customer privacy policies and standards take account of and comply with all privacy regulations and laws applicable to the jurisdictions to which it is providing e-services;
 - b. Customers are made aware of the BSI's privacy policies and relevant privacy issues concerning use of e-services;
 - c. Customers may decline ("opt out") from permitting the BSFI to share with a third party for cross-marketing purposes any information about the customer's personal needs, interests, financial position or banking activity; and
 - d. Customer data are not used for purposes beyond which they are specifically allowed or for purposes beyond which customers have authorized. The BSFI's standards for customer data use must be met when third parties have access to customer data through outsourcing relationships.
- 4.3.2. Information Disclosure for E-Services. The BSFI should comply with all legal requirements relating to e-services, including the responsibility to provide its customers with appropriate disclosures and to protect customer data. Failure to comply with these responsibilities could result in significant compliance, legal, or reputation risk for the BSFI.

The BSFI should set out clearly in its terms and conditions the respective rights and obligations between the BSFI and its customers. These terms and conditions should be fair and balanced to both parties. In addition, it is required to provide its customers with a level of comfort regarding information disclosures or transparencies, protection of customer data and business availability that they can expect when using traditional banking services. To minimize operational, legal and reputational risks associated with e-services activities, the BSFI should make adequate disclosures of information and take appropriate measures to ensure adherence to customer privacy and protection requirements. Annex "B" provides for the minimum disclosure requirements of BSFI's.

- 4.3.3. **Consumer Awareness.** Customer education is a key defense against fraud, identity theft and security breach. Therefore, BSFI's should pay special attention to the provision of easy to understand and prominent advice to its customers on security precautions for e-services. As an integral part of their customer onboarding process, BSFI's shall ensure that their clients have undertaken a pre-requisite consumer education course/program on the safe and secure use of electronic payment and financial services (EPFS), including the associated risks. To effectively capture the customer's attention and interest and reinforce

their awareness and understanding of risks, BSFIs should explore the use of interactive platforms/materials such as but not limited to video clips, online quizzes, infographics, etc. BSFIs shall likewise adopt a program aimed at promoting continuing awareness and constantly reminding its clients on the safe and secure use of EPFS, including the associated risks.

BSFIs should maintain and continuously evaluate its consumer awareness program. Methods to evaluate a program's effectiveness include tracking the number of customers who report fraudulent attempts to obtain their authentication credentials, the number of clicks on information security links on websites, the number of inquiries, etc. *Annex "C"* provides for the minimum Consumer Awareness Program that the BSFI should convey to its customers.

- 4.3.4. Complaints Resolution. The BSFI may receive customer complaint either through an electronic medium or otherwise, concerning unauthorized transactions, loss or theft in the e-services account. Therefore, it should ensure that controls are in place to review these notifications and that an investigation is initiated as required. The BSFI should also establish procedures to resolve disputes arising from the use of the e-services.

4.4. Cross-Border E-Banking Activities.

- 4.4.1. Before a BSFI initiates cross-border e-services, its management should conduct appropriate risk assessment and due diligence to ensure that it can adequately manage the attendant risks. It must also comply with any applicable laws and regulations, both the home country as well as those of any foreign country that may assert jurisdiction over e-services that are directed at its residents. Further, the BSFI should ensure that it has an effective and ongoing risk management program for its cross-border e-services activities;
- 4.4.2. Before engaging in transactions involving cross-border e-services with foreign customers, the BSFI should ensure that adequate information is disclosed on its Web site to allow potential customers to make a determination of the BSFI's identity, home country, and whether it has the relevant regulatory license(s) before it establishes the relationship. This information will help improve transparency and minimize legal and reputational risk associated with the offering of cross border e-services.

5. INDEPENDENT ASSESSMENT

- 5.1. An appropriate independent audit function is also an important component of a BSFI's monitoring mechanisms. The audit coverage should be expanded commensurate with the increased complexity and risks inherent in e-services and should include the entire process as applicable (i.e., network configuration and security, interfaces to legacy systems, regulatory compliance, internal controls, support activities performed by third-party providers etc.).
- 5.2. The BSFI should also make arrangements for independent assessments to be conducted on its systems before the launch of the relevant services or major enhancements to existing services. The person(s) (i.e., the assessor) contracted by the BSFI to perform independent assessment should have, and be able to demonstrate, the necessary expertise in the relevant fields. He/she should be independent from the parties that develop or administer the system and should not be involved in the operations to be reviewed or in selecting or implementing the relevant control measures to be reviewed. He/she should be able to report findings freely and directly to the authorized BSFI senior management.
- 5.3. Subsequent to an initial independent assessment, the BSFI should conduct risk assessment at least every two (2) years or when there are substantial changes to determine if further independent assessment should be required and the frequency and scope of such independent assessment. Any substantial changes to the risk profile of the services being provided, significant modifications of the network infrastructure and applications, material system vulnerabilities or major security breaches are to be taken into consideration in the risk assessment.

6. APPLICABILITY

- 6.1. These guidelines are intended for all electronic products and services offered by BSFIs to their customers. These are focused on the risks and risk management techniques associated with electronic delivery channels to protect customers and general public. It should be understood, however, that not all the customer protection issues that have arisen in connection with new technologies are specifically addressed in subject guidelines. Additional issuances may be issued in the future to address other aspects of consumer protection as the financial service environment through e-services evolves.

(As amended by Circular No. 1140 dated 24 March 2022)

SECURITY CONTROLS ON SPECIFIC ELECTRONIC SERVICES AND CHANNELS

In providing banking/financial services via electronic channels, such as ATM, internet and mobile devices, the BSFI must consider customer's convenience in using the facilities, including the effectiveness of the display on electronic menu, particularly on customer's instructions selection menu in order to avoid any error and loss in transactions. In electronic services which involve physical equipment like ATMs, the BSFI must implement physical security control on equipments and rooms from the danger of theft, sabotage and other criminal actions by unauthorized parties. It must perform routine monitoring to ensure security and comfort of customers using electronic service.

Automated Teller Machine (ATM)

1. To minimize/prevent ATM frauds and crimes, the BSFI, at a minimum, implement the following security measures with respect to its ATM facilities:
 - a. Locate ATM's in highly visible areas;
 - b. Provide sufficient lighting at and around the ATMs;
 - c. Where ATM crimes (e.g., robbery, vandalism, skimming) are high in a specific area or location, the BSFI should install surveillance camera or cameras which shall view and record all persons entering the facility. Such recordings shall be preserved by the BSFI for at least thirty (30) days;
 - d. Implement ATM programming enhancements like masking/non-printing of card numbers;
 - e. Educate customers by advising them regularly of risks associated with using the ATM and how to avoid these risks;
 - f. Conduct and document periodic security inspection at the ATM location;
 - g. Educate BSFI personnel to be responsive and sensitive to customer concerns; and
 - h. Post a clearly visible sign near the ATM facility which, at a minimum, provides the telephone numbers of the BSFI as well as other BSFI's hotline numbers for other cardholders who are allowed to transact business in the ATM, and police hotlines for emergency cases.
2. The BSFI must study and assess ATM crimes to determine the primary problem areas. Procedures for reporting ATM crimes should also be established. Knowing what crimes have occurred will aid the BSFI in recognizing the particular problem and to what degree it exists so that it can implement the necessary preventive measures. In this connection, all BSFI's are encouraged to share information involving ATM fraud cases to deter and prevent proliferation of the crime.

Online Internet Financial Services

1. Assurance should be provided that online login access and transactions performed over the internet are adequately protected and authenticated. In addition, customers should be adequately educated on security measures that must be put in place to uphold their interests in the online environment.
2. With internet connection to internal networks, financial systems and devices may now be potentially accessed by anyone from anywhere at any time. The BSFI should implement physical and logical access security to allow only authorized personnel to access its systems. Appropriate processing and transmission controls should also be implemented to protect the integrity of systems and data.
3. There should be a mechanism to authenticate official website to protect customers from spoofed or faked websites. The BSFI should determine what authentication technique to adopt to provide protection against these attacks. For wireless applications, it should adopt authentication protocols that are separate and distinct from those provided by the wireless network operator.
4. Monitoring or surveillance systems should be implemented to alert BSFI of any erratic system activities, transmission errors or unusual online transactions. A follow-up process should be established to verify that these issues or errors are adequately addressed subsequently. High resiliency and availability of online systems and supporting systems (such as interface systems, backend host systems and network equipment) should be maintained to meet customers' expectations. Measures to plan and track capacity utilization as well as guard against online attacks should be established.

5. As more customers log into BSFI's website to access their accounts and conduct a wide range of financial transactions for personal and business purposes, a suite of measures must be established to protect customers' interests in using online systems. Furthermore, customers should be educated on the risks of using online financial services before they subscribe to such services. Ongoing education must be available to raise the security awareness of customers to protect their systems and online transactions.

Mobile and Phone Financial Services

1. For electronic services using mobile phone, the BSFI must ensure the security of transactions by implementing the following, among others:
 - a. Employment of a SIM Toolkit with end-to-end encryption feature from hand phones to m-banking servers, to protect data transmission in m-banking; and
 - b. Adoption of dual authentication process (i.e., MPIN) to ensure that the party initiating the transaction is the owner of the device and is authorized to perform such transaction.
2. For phone banking and other financial services, the BSFI must ensure the security of transactions, by implementing the following, among others:
 - a. The service shall not be used for transactions with high value or risk;
 - b. All IVR conversations shall be recorded, including customer's phone number, transaction detail, etc;
 - c. The service shall use reliable and secure authentication methods; and
 - d. The use of customer authentication method such as PIN and password for financial transactions.

Other Mobile Online and Payment Services

1. Mobile online and payment services are extensions of the online financial services which are offered by the BSFI and accessible from the internet via computers, laptops and similar devices. Security measures which are similar to those of online financial and payment systems should also be implemented on the mobile online services and payment systems. A risk assessment should be conducted to identify possible fraud scenarios and appropriate measures should be established to counteract payment card fraud via mobile devices.
2. The BSFI may require customers to download its mobile online services and payment applications directly from third party repositories (e.g., Apple store, Google Play and Windows Market Place) on to mobile devices. Customers must be able to verify the integrity and authenticity of the application prior to its download. The BSFI should also be able to check the authenticity and integrity of the software being used by the customers.
3. As mobile devices are susceptible to theft and loss, there must be adequate protection of sensitive data used for mobile online services and payments. Sensitive data confidentiality and integrity of these data in storage, transmission and during processing.
4. Customers should be educated on security measures to protect their own mobile devices from theft and loss as well as viruses and other errant software which cause malicious damage and harmful consequences.

Point of Sale Devices

1. Point of Sale (POS)/Electronic Data Capture (EDC) enable electronic fund transfer from customer's account to acquirer's or merchant's account for payment of a transaction. The party providing POS terminal must always increase the physical security around the vicinity of such POS terminal and on the POS terminal itself, among others, by using POS terminal that minimizes the possibility of interception on such terminal or in its communication network.
2. The BSFI deploying POS devices at merchant locations must familiarize the merchant with the safe operation of the device. The acquiring institution must ensure that the POS devices as well as other devices that capture information do not expose/store information such as the PIN number or other information classified as confidential. It must also ensure that a customer's PIN number cannot be printed at the point of sale for any reason whatsoever.
3. Operators of point of sale devices are encouraged to work towards interoperability of cards from other schemes.

Electronic Payment Cards (ATM, Credit and Debit Cards)

1. Payment cards allow cardholders the flexibility to make purchases wherever they are. Payment cards exist in many forms; with magnetic stripe cards posing the highest security risks. Sensitive payment card data stored on magnetic stripe cards is

vulnerable to card skimming attacks. Card skimming attacks can happen at various points of the payment card processing, including payment kiosks and POS terminals. In addition to counterfeit/skimmed cards, fraudulent activities associated with payment cards include lost/stolen cards, card-not-received and card-not-present transactions.

2. The BSFI providing payment card services should implement adequate safeguards to protect sensitive payment card data. Sensitive payment card data should be encrypted to ensure the confidentiality and integrity of these data in storage, transmission and during processing. Pending the required adoption of EMV chip-cards by 01 January 2017, all BSFIs engaged in the payment card business should consider implementing the following measures to mitigate exposure from skimming attacks:
 - a. Installation of anti-skimming solutions on ATM and POS machines to detect the presence of foreign devices placed over or near a card entry slot;
 - b. Establishment of detection and alert mechanisms to appropriate personnel for follow-up response and action;
 - c. Implementation of tamper-resistant keypads to ensure that no one can identify which buttons are being pressed by customers;
 - d. Implementation of appropriate measures to prevent shoulder surfing of customers' PINs; and
 - e. Conduct video surveillance of activities at these machines and maintain the quality of CCTV footage.
3. New payment cards sent to customers via courier should only be activated upon obtaining the customer's instruction. Online transactions should only be allowed if authorized by the customers. Authentication of customers' sensitive static information, such as personal identification number (PIN) or passwords, should be performed by the card issuer and not by third party payment processing service providers. Appropriate security mechanisms should also be implemented for card-not-present transactions via internet to reduce fraud risk associated with this type of transaction.
4. To enhance payment card security, cardholders should be notified promptly via transaction alerts on withdrawals/charges exceeding customer-defined thresholds made on their payment cards. The transaction alert should include information such as source and amount of the transaction to assist customers in identifying a genuine transaction.
5. Fraud detection systems with behavioral scoring and correlation capabilities should be implemented to identify and curb fraudulent activities. Risk management parameters should be calibrated according to risks posed by cardholders, nature of transactions or other risk factors to enhance fraud detection capabilities. Follow-up actions for transactions exhibiting behavior which deviates significantly from a cardholder's usual card usage patterns should be instituted. These transactions should be investigated into and the cardholder's authorization obtained prior to completing the transaction.